

به نام خدا

دانشگاه آزاد اسلامی

رشته‌ی مهندسی کامپیوتر



گزارش پروژه

طراحی و پیاده‌سازی فروشگاه اینترنتی «تک‌شاپ»

با استفاده از PostgreSQL و Django، Django REST Framework، React

جناب آقای سجاد پیراهش	استاد مربوطه
محمد مهدی پولادگر	تهیه‌کننده
مهندسی کامپیوتر	رشته
دانشگاه آزاد اسلامی	دانشگاه
مهر ۱۴۰۵	زمان

به نام خدا

دانشگاه آزاد اسلامی

رشته‌ی مهندسی کامپیوتر



گزارش پروژه

طراحی و پیاده‌سازی فروشگاه اینترنتی «تک‌شاپ»

با استفاده از PostgreSQL و Django، Django REST Framework، React

جناب آقای سجاد پیراهش	استاد مربوطه
محمد مهدی پولادگر	تهیه‌کننده
مهندسی کامپیوتر	رشته
دانشگاه آزاد اسلامی	دانشگاه
مهر ۱۴۰۵	زمان

تشکر و قدردانی

سپاس بی‌کران خدای مهربان را که توفیق انجام این پروژه را عطا فرمود.

از استاد گران‌قدر، جناب آقای سجاد پیراهش، به‌خاطر راهنمایی‌ها، نکته‌سنجی‌ها و فرصتی که برای یادگیری عملی فراهم کردند، صمیمانه سپاسگزارم.

از خانواده‌ام که در تمام مراحل تحصیل همراه و پشتیبانم بودند، و از همکلاسی‌ها و دوستانی که با نظرات خود در بهبود این کار کمک کردند، قدردانی می‌کنم.

چکیده

این گزارش مراحل تحلیل، طراحی، پیاده‌سازی و آزمون «تک‌شاپ» را شرح می‌دهد؛ یک فروشگاه اینترنتی کالای دیجیتال که برای مشتریان ایرانی و به زبان فارسی (راست‌به‌چپ) ساخته شده است. بخش سرور با زبان Python و چارچوب Django و Django REST Framework نوشته شده و داده‌ها در PostgreSQL ذخیره می‌شوند؛ Redis برای نشست، کش، محدودیت نرخ و قفل سفارش، و RabbitMQ و Celery برای کارهای زمان‌بندی‌شده به کار رفته‌اند. رابط کاربری از دو برنامه‌ی تک‌صفحه‌ای React و Vite ساخته شده است: ویتترین فروشگاه برای مشتریان و پنل مدیریت برای کارکنان.

سامانه شامل مرور و جست‌وجوی محصولات با فیلتر، سبد خرید مبتنی بر نشست، ثبت‌نام و ورود، مدیریت پروفایل و آدرس، ثبت سفارش با تراکنش اتمیک، پیگیری وضعیت سفارش، وبلاگ، فرم تماس و پنل مدیریت است. در طراحی به امنیت (CSRF، محدودیت نرخ، اعتبارسنجی)، دسترس‌پذیری و واکنش‌گرایی توجه شده و یک کیت طراحی اختصاصی با رنگ‌های سورمه‌ای و کورال ساخته شده است. کیفیت کار با ۱۷۳ آزمون خودکار، آزمون‌های انتها‌به‌انتها با Playwright و یک بازبینی امنیتی مستقل سنجیده شد که ایرادهای یافت‌شده در آن برطرف گردید.

گزارش با دیاگرام‌های UML (موارد کاربرد، توالی، فعالیت، حالت)، نمودار موجودیت-رابطه، معماری و استقرار، سناریوهای کاربردی و جدول فناوری‌ها همراه است.

کلیدواژه‌ها: فروشگاه اینترنتی، Redis، PostgreSQL، REST API، Vite، React، Django، تجربه کاربری، آزمون نرم‌افزار

Abstract

This report describes the analysis, design, implementation and testing of TechShop, an online store for digital goods built for Persian-speaking customers with a right-to-left interface. The server side is written in Python with Django and Django REST Framework and stores its data in PostgreSQL; Redis is used for sessions, caching, rate limiting and an order lock, and RabbitMQ with Celery runs scheduled jobs. The user interface consists of two single-page applications built with React and Vite: the storefront for customers and an admin panel for staff.

The system offers product browsing and filtered search, a session-based shopping cart, registration and login, profile and address management, order placement inside an atomic transaction, order tracking, a blog, a contact form and an administration panel. The design pays attention to security (CSRF protection, rate limiting, input validation), accessibility and responsiveness, and includes a custom design kit based on navy and coral colors. Quality was checked with 173 automated tests, end-to-end browser tests with Playwright and an independent security review whose findings were fixed.

The report contains UML use-case, sequence, activity and state diagrams, an entity-relationship diagram, architecture and deployment diagrams, usage scenarios and a table of technologies.

Keywords: Online store, Django, React, Vite, REST API, PostgreSQL, Redis, User experience, Software testing

فهرست مطالب

۱	فصل ۱: مقدمه
۱	۱-۱ پیش‌گفتار
۱	۱-۲ بیان مسئله
۱	۱-۳ اهمیت و ضرورت
۲	۱-۴ اهداف پروژه
۲	۱-۵ دامنه و محدودیت‌ها
۳	۱-۶ روش انجام کار
۳	۱-۷ ساختار گزارش
۴	فصل ۲: تحلیل نیازمندی‌ها و سناریوها
۴	۲-۱ ذی‌نفعان و نقش‌ها
۴	۲-۲ نیازمندی‌های عملکردی
۶	۲-۳ نیازمندی‌های غیرعملکردی
۶	۲-۴ نمودار موارد کاربرد
۷	۲-۵ سناریوهای کاربردی
۱۰	۲-۶ نمودار فعالیت فرایند خرید
۱۲	فصل ۳: فناوری‌های به‌کاررفته
۱۲	۳-۱ معیارهای انتخاب فناوری
۱۲	۳-۲ پشته‌ی سمت سرور
۱۴	۳-۳ پشته‌ی سمت کاربر
۱۵	۳-۴ ابزارهای توسعه و کیفیت
۱۵	۳-۵ مقایسه‌ی گزینه‌ها و دلیل انتخاب
۱۶	فصل ۴: طراحی و معماری سیستم
۱۶	۴-۱ معماری کلی
۱۶	۴-۲ معماری سمت سرور
۱۷	۴-۳ طراحی پایگاه داده
۱۸	۴-۴ طراحی API
۱۹	۴-۵ نمودارهای توالی
۲۱	۴-۶ وضعیت سفارش
۲۲	۴-۷ معماری سمت کاربر
۲۳	۴-۸ طراحی رابط کاربری
۲۴	۴-۹ طراحی امنیت
۲۵	۴-۱۰ استقرار
۲۶	فصل ۵: پیاده‌سازی

۲۶	۵-۱ ساختار پروژه
۲۶	۵-۲ نکات کلیدی پیاده‌سازی سمت سرور
۲۸	۵-۳ نکات کلیدی پیاده‌سازی سمت کاربر
۲۸	۵-۴ تصاویر محیط کاربری
۳۴	۵-۵ داده‌ی نمونه و تصویرسازی
۳۵	فصل ۶: آزمون و ارزیابی
۳۵	۶-۱ راهبرد آزمون
۳۵	۶-۲ آزمون‌های سمت سرور
۳۶	۶-۳ آزمون‌های انتها به انتها
۳۶	۶-۴ بازیابی امنیتی مستقل
۳۷	۶-۵ کیفیت رابط کاربری
۳۸	۶-۶ جمع‌بندی ارزیابی
۳۹	فصل ۷: نتیجه‌گیری و پیشنهادها
۳۹	۷-۱ نتیجه‌گیری
۳۹	۷-۲ محدودیت‌ها
۳۹	۷-۳ پیشنهادها برای ادامه‌ی کار
۴۱	منابع
۴۲	پیوست‌ها
۴۲	پیوست الف: API مدیریتی (JWT)
۴۳	پیوست ب: دستورهای اجرا
۴۳	پیوست پ: آمار پروژه
۴۴	پیوست ت: واژه‌نامه‌ی اصطلاحات

فهرست شکل‌ها

۳	شکل ۱-۱: زمان‌بندی نسبی مراحل انجام پروژه
۷	شکل ۲-۲: نمودار موارد کاربرد سامانه تک‌شاپ
۱۱	شکل ۳-۲: نمودار فعالیت فرایند خرید
۱۲	شکل ۴-۳: نمای کلی پشت‌پشت فناوری و لایه‌های سامانه
۱۷	شکل ۵-۴: نمودار موجودیت-رابطه‌ی پایگاه داده
۲۰	شکل ۶-۴: نمودار توالی ورود کاربر
۲۰	شکل ۷-۴: نمودار توالی افزودن کالا به سبد
۲۱	شکل ۸-۴: نمودار توالی ثبت سفارش
۲۱	شکل ۹-۴: نمودار حالت سفارش و تراکنش
۲۲	شکل ۱۰-۴: ساختار مؤلفه‌های برنامه‌ی React
۲۳	شکل ۱۱-۴: نقشه‌ی صفحه‌های وب‌ترین فروشگاه
۲۳	شکل ۱۲-۴: پالت رنگ سامانه (مقیاس سورمه‌ای، کورال و رنگ‌های وضعیت)
۲۴	شکل ۱۳-۴: لایه‌های امنیتی عبور درخواست
۲۵	شکل ۱۴-۴: نمودار استقرار در محیط توسعه و Docker Compose
۲۹	شکل ۱۵-۵: صفحه‌ی اصلی در نسخه‌ی دسکتاپ
۲۹	شکل ۱۶-۵: فروشگاه با پنل فیلتر، مرتب‌سازی و کارت‌های محصول
۳۰	شکل ۱۷-۵: صفحه‌ی جزئیات محصول با کارت خرید ثابت
۳۰	شکل ۱۸-۵: سبد خرید با نوار پیشرفت ارسال رایگان
۳۱	شکل ۱۹-۵: صفحه‌ی بررسی و ثبت سفارش
۳۱	شکل ۲۰-۵: صفحه‌ی ورود با پنل برند
۳۲	شکل ۲۱-۵: حساب کاربری و نوار کامل‌بودن پروفایل
۳۲	شکل ۲۲-۵: فهرست مقاله‌های وبلاگ با جلد تصویرسازی‌شده
۳۳	شکل ۲۳-۵: صفحه‌ی اصلی در موبایل
۳۳	شکل ۲۴-۵: منوی کشویی موبایل
۳۴	شکل ۲۵-۵: داشبورد پنل مدیریت

فهرست جدول‌ها

۲	جدول ۱-۱: اهداف پروژه و معیار سنجش هر هدف
۴	جدول ۲-۲: نقش‌ها و دسترسی هر نقش
۴	جدول ۳-۲: نیازمندی‌های عملکردی
۶	جدول ۴-۲: نیازمندی‌های غیرعملکردی و روش تأمین آن‌ها
۷	جدول ۵-۲: سناریوی مرور و جست‌وجو
۸	جدول ۶-۲: سناریوی سبد خرید
۸	جدول ۷-۲: سناریوی ثبت‌نام و ورود
۹	جدول ۸-۲: سناریوی ثبت سفارش

۹	جدول ۲-۹: سناریوی پروفایل و آدرس
۱۰	جدول ۲-۱۰: سناریوی پنل مدیریت
۱۲	جدول ۳-۱۱: فناوری‌های سمت سرور
۱۴	جدول ۳-۱۲: فناوری‌های سمت کاربر
۱۵	جدول ۳-۱۳: ابزارهای توسعه و کیفیت
۱۵	جدول ۳-۱۴: گزینه‌های بررسی‌شده و تصمیم نهایی
۱۶	جدول ۴-۱۵: اپ‌های Django و مسئولیت هر کدام
۱۸	جدول ۴-۱۶: موجودیت‌های اصلی و نقش آن‌ها
۱۸	جدول ۴-۱۷: API عمومی فروشگاه (پیش‌وند / /shop/api/v1/public)
۱۹	جدول ۴-۱۸: API مشتری (پیش‌وند / /accounts/api/v1/customer)
۲۳	جدول ۴-۱۹: توکن‌های اصلی طراحی
۲۴	جدول ۴-۲۰: اقدامات امنیتی و تهدیدی که پوشش می‌دهند
۳۵	جدول ۶-۲۱: خلاصه‌ی آزمون‌های pytest (در مجموع ۱۷۳ آزمون موفق)
۳۶	جدول ۶-۲۲: مراحل آزمون انتها به انتهای فروشگاه
۳۶	جدول ۶-۲۳: یافته‌های بازبینی امنیتی و رفع آن‌ها
۳۷	جدول ۶-۲۴: اندازه‌ی بسته‌ی ساخته‌شده‌ی فرانت‌اند (بر حسب کیلوبایت)
۳۹	جدول ۷-۲۵: محدودیت‌های نسخه‌ی فعلی
۴۲	جدول ۷-۲۶: گروه‌های API مدیریتی و مسیرهای هر گروه
۴۳	جدول ۷-۲۷: آمار کلی پروژه در زمان نگارش گزارش
۴۴	جدول ۷-۲۸: اصطلاحات فنی به‌کاررفته در گزارش

فصل ۱: مقدمه

۱-۱ پیش‌گفتار

خرید اینترنتی در سال‌های اخیر به یکی از رایج‌ترین روش‌های تهیه‌ی کالا تبدیل شده است. کالاهای دیجیتال مانند گوشی هوشمند، تبلت و هدفون به دلیل مشخصات فنی متنوع و قیمت‌های متغیر، بیش از سایر کالاها به یک فروشگاه اینترنتی منظم نیاز دارند؛ فروشگاه‌هایی که مشخصات را شفاف نشان دهد، مقایسه و جست‌وجو را ساده کند و فرایند خرید را کوتاه و قابل‌اعتماد نگه دارد.

این گزارش، پروژه‌ی «تک‌شاپ» را معرفی می‌کند: یک فروشگاه اینترنتی کالای دیجیتال با رابط فارسی و راست‌به‌چپ که از دو بخش اصلی تشکیل شده است؛ سرویس‌دهنده‌ی (Backend) نوشته‌شده با Django و ارائه‌دهنده‌ی API، و رابط کاربری (Frontend) نوشته‌شده با React. هدف گزارش این است که مراحل مهندسی نرم‌افزار، از تحلیل نیازمندی‌ها تا طراحی، پیاده‌سازی و آزمون، به صورت مستند و همراه با دیاگرام‌ها و سناریوها ارائه شود.

۱-۲ بیان مسئله

فروشگاه‌های اینترنتی ساده اغلب با چند مشکل تکراری روبه‌رو هستند: رابط کاربری قدیمی و ناسازگار با موبایل، نبود جداسازی روشن میان بخش نمایش و بخش داده، ضعف در امنیت فرم‌ها و نشست کاربر، و نبود آزمون خودکار که تغییرات بعدی را پرخطر می‌کند. در پروژه‌ی پیش از بازطراحی نیز صفحه‌ها به صورت قالب‌های سمت سرور (Django Templates) ارائه می‌شدند و ظاهر سایت به فایل‌های CSS و تصاویر قدیمی وابسته بود.

مسئله‌ی این پروژه آن است که یک فروشگاه کامل و قابل توسعه ساخته شود که: (الف) فرایند خرید را از مرور محصول تا ثبت سفارش پوشش دهد، (ب) رابط کاربری مدرن، سریع و واکنش‌گرا داشته باشد، (پ) امنیت و درستی داده‌ها را در سناریوهای ناهنجار (مانند دوبار کلیک روی دکمه‌ی پرداخت) حفظ کند و (ت) با آزمون‌های خودکار قابل راستی‌آزمایی باشد.

۱-۳ اهمیت و ضرورت

- جداسازی API از رابط کاربری امکان استفاده‌ی مجدد از یک سرویس برای وب، موبایل و پنل مدیریت را فراهم می‌کند.

- رابط تک‌صفحه‌ای (SPA) بدون بارگذاری مجدد صفحه، تجربه‌ی روان‌تری برای مرور و خرید ایجاد می‌کند.
- محافظت در برابر حملاتی مانند CSRF و حدس‌زدن گذرواژه برای هر سیستمی که با اطلاعات کاربران سروکار دارد ضروری است.
- آزمون خودکار، هزینه‌ی تغییر و نگهداری نرم‌افزار را کاهش می‌دهد و اطمینان می‌دهد ویژگی‌های قبلی خراب نمی‌شوند.

۱-۴ اهداف پروژه

جدول ۱-۱: اهداف پروژه و معیار سنجش هر هدف

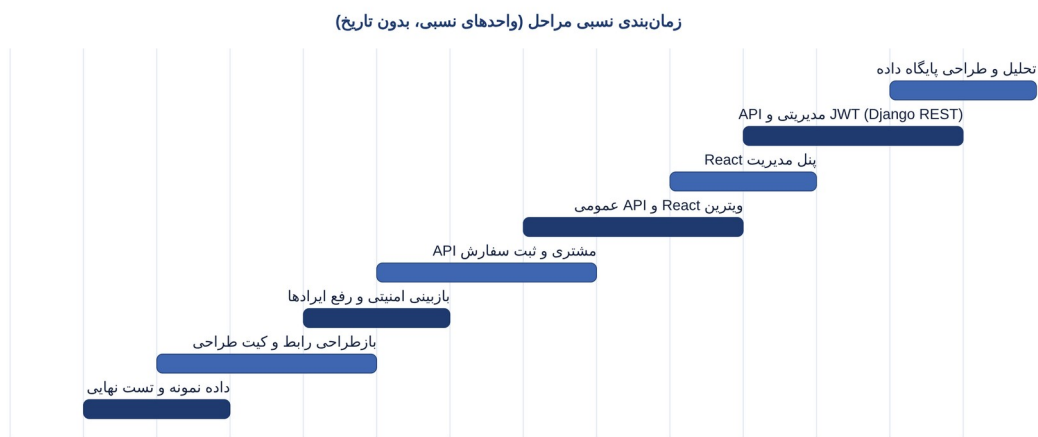
ردیف	هدف	معیار تحقق
۱	ساخت API کامل برای محصول، سبد، سفارش و کاربر	مستندات Swagger و آزمون‌های خودکار موفق
۲	ساخت ویترین فروشگاه با React	دسترسی به همه‌ی صفحه‌های فرایند خرید در دسکتاپ و موبایل
۳	ساخت پنل مدیریت	مدیریت دسته‌بندی، محصول، سفارش و کاربر با ورود JWT
۴	امنیت نشست و فرم‌ها	CSRF، محدودیت نرخ و اعتبارسنجی همراه با آزمون
۵	ثبت سفارش درست و بدون تکرار	تراکنش اتمیک، قفل کاربر و آزمون همزمانی
۶	رابط زیبا، یکدست و دسترس‌پذیر	کیت طراحی با توکن رنگ، تباین متن حداقل ۴/۵ به ۱
۷	داده‌ی نمونه‌ی واقع‌نما	دستورهای seed برای ۴۳ محصول و ۳ مقاله

۱-۵ دامنه و محدودیت‌ها

دامنه‌ی پروژه شامل مرور و جست‌وجوی محصول، سبد خرید، حساب کاربری، ثبت سفارش، وبلاگ، فرم تماس و پنل مدیریت است. چند مورد عمداً خارج از دامنه‌ی نسخه‌ی فعلی مانده است: اتصال به درگاه پرداخت واقعی (سفارش با وضعیت «در انتظار پرداخت» ذخیره می‌شود)، مدیریت موجودی انبار هنگام ثبت سفارش، ارسال ایمیل و پیامک، و استقرار نهایی روی سرور عمومی.

۱-۶ روش انجام کار

کار به صورت تکراری و گام به گام (نزدیک به رویکرد چابک) انجام شد: هر گام یک قابلیت مشخص را می‌ساخت، با آزمون خودکار تأیید می‌شد و در Git ثبت می‌گردید. مخزن پروژه روی GitHub نگهداری می‌شود و تا زمان نگارش این گزارش بیش از ۹۰ کامیت دارد. ابزارهای کمکی شامل ویرایشگر کد، مرورگر Chromium برای آزمون‌های خودکار و یک دستیار هوش مصنوعی برنامه‌نویسی (Claude Code) برای تولید و بازبینی بخشی از کد بود؛ تمامی خروجی‌ها پیش از ثبت اجرا و آزمایش شدند.



شکل ۱-۱: زمان‌بندی نسبی مراحل انجام پروژه

۱-۷ ساختار گزارش

فصل دوم نیازمندی‌ها، نقش‌ها و سناریوهای کاربردی را تحلیل می‌کند. فصل سوم فناوری‌های به‌کاررفته و دلیل انتخاب هر یک را بیان می‌کند. فصل چهارم معماری، پایگاه داده، API و امنیت را با دیاگرام‌ها شرح می‌دهد. فصل پنجم جزئیات پیاده‌سازی و تصاویر محیط کاربری را ارائه می‌کند. فصل ششم آزمون‌ها و ارزیابی را می‌آورد و فصل هفتم جمع‌بندی و پیشنهادهای آینده است. در پایان منابع و پیوست‌ها آمده‌اند.

فصل ۲: تحلیل نیازمندی‌ها و سناریوها

۲-۱ ذی‌نفعان و نقش‌ها

سه نقش اصلی در سامانه تعریف شده است. مهمان بدون ورود می‌تواند محصولات را ببیند و سبد بسازد. مشتری پس از ثبت‌نام و ورود، سفارش ثبت و پیگیری می‌کند. مدیر با حساب کارمند (is_staff) به پنل مدیریت وارد می‌شود. نقش دیگری به نام توسعه‌دهنده/نگهدار وجود دارد که با سامانه از راه مستندات API و پنل مدیریت جنگو (Jazzmin) کار می‌کند.

جدول ۲-۲: نقش‌ها و دسترسی هر نقش

نقش	توضیح	دسترسی اصلی
مهمان	بازدیدکننده ثبت‌نام‌نکرده	مرور، جست‌وجو، سبد خرید، وبلاگ، فرم تماس، ثبت‌نام و ورود
مشتری	کاربر واردشده	پروفایل، آدرس، تغییر گذرواژه، ثبت و پیگیری سفارش
مدیر	کاربر با is_staff	پنل مدیریت: داشبورد، دسته‌بندی، محصول، سفارش و کاربر
توسعه‌دهنده	نگهدار فنی	Jazzmin، Swagger، ReDoc، پنل اجرا seed و آزمون‌ها

۲-۲ نیازمندی‌های عملکردی

نیازمندی‌های عملکردی در جدول زیر فهرست شده‌اند. هر نیازمندی شناسه‌ای یکتا دارد تا در آزمون‌ها و سناریوها به آن ارجاع داده شود.

جدول ۳-۲: نیازمندی‌های عملکردی

شناسه	نیازمندی	نقش
FR-۰۱	نمایش فهرست محصولات با صفحه‌بندی (۱۲ مورد در هر صفحه)	مهمان
FR-۰۲	فیلتر محصولات بر اساس دسته، برند، رنگ، بازه‌ی قیمت، موجودی و تخفیف	مهمان
FR-۰۳	مرتب‌سازی بر اساس پیشنهاد خریداران، جدیدترین، ارزان‌ترین، گران‌ترین و سریع‌ترین ارسال	مهمان

شناسه	نیازمندی	نقش
FR-۰۴	جست‌وجوی متنی در نام و مشخصات محصول	مهمان
FR-۰۵	نمایش جزئیات محصول: تصاویر، مشخصات، قیمت با تخفیف و موجودی	مهمان
FR-۰۶	افزودن، تغییر تعداد و حذف کالا در سبد خرید بدون نیاز به ورود	مهمان
FR-۰۷	حفظ سبد خرید پس از ورود به حساب	مهمان
FR-۰۸	ثبت‌نام با نام کاربری، ایمیل، نام و گذرواژه	مهمان
FR-۰۹	ورود و خروج با نشست امن	مشتری
FR-۱۰	مشاهده و ویرایش پروفایل (شامل تصویر)	مشتری
FR-۱۱	ثبت و ویرایش آدرس تحویل	مشتری
FR-۱۲	تغییر گذرواژه با تأیید گذرواژه‌ی فعلی	مشتری
FR-۱۳	ثبت سفارش از روی سبد (ایجاد سفارش، فاکتور و تراکنش)	مشتری
FR-۱۴	جلوگیری از ثبت سفارش تکراری در دوبار کلیک	مشتری
FR-۱۵	فهرست سفارش‌ها، جزئیات و وضعیت هر سفارش	مشتری
FR-۱۶	نمایش آخرین سفارش	مشتری
FR-۱۷	مطالعه‌ی مقالات وبلاگ با فیلتر دسته‌بندی	مهمان
FR-۱۸	ارسال پیام از فرم تماس با اعتبارسنجی شماره	مهمان
FR-۱۹	ورود مدیر با JWT و تازه‌سازی خودکار توکن	مدیر
FR-۲۰	داشبورد آمار (شمار سفارش، کاربر، محصول و مدیر)	مدیر
FR-۲۱	افزودن، ویرایش و حذف دسته‌بندی همراه با تصویر	مدیر
FR-۲۲	فهرست و حذف محصولات	مدیر
FR-۲۳	فهرست سفارش‌ها و کاربران با جست‌وجو	مدیر

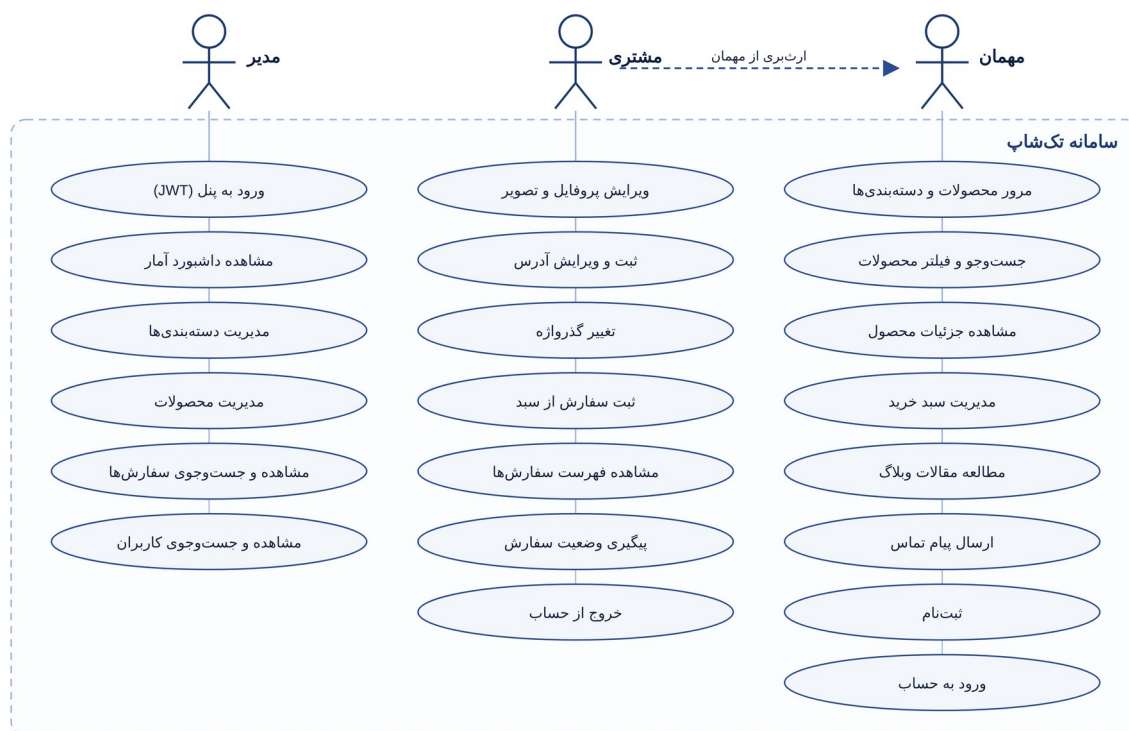
۲-۳ نیازمندی‌های غیرعملکردی

جدول ۲-۴: نیازمندی‌های غیرعملکردی و روش تأمین آن‌ها

شناسه	ویژگی کیفی	روش تأمین
NFR-۰۱	امنیت	CSRF روی نمای‌های API، محدودیت نرخ ورود و ثبت‌نام، نشست در Redis، SECRET_KEY از محیط
NFR-۰۲	درستی داده	تراکنش اتمیک، قفل کاربر در ثبت سفارش، اعتبارسنجی ورودی و محدودیت مقادیر
NFR-۰۳	قابلیت استفاده	رابط فارسی راست‌به‌چپ، پیام‌های خطای روشن، حالت‌های بارگذاری، خالی و خطا
NFR-۰۴	واکنش‌گرایی	طراحی موبایل‌اول؛ نبود اسکرول افقی از ۳۲۰ تا ۱۴۴۰ پیکسل
NFR-۰۵	دسترس‌پذیری	تباین متن حداقل ۴/۵ به ۱، برچسب فیلدها، ناوبری با صفحه‌کلید، کاهش حرکت
NFR-۰۶	کارایی	بارگذاری تنبیل صفحه‌ها (lazy chunks)، تصاویر تنبیل، کش نشست در حافظه
NFR-۰۷	نگهداشت‌پذیری	کیت طراحی مشترک، توکن‌های طراحی، آزمون‌های خودکار، توضیحات انگلیسی در کد
NFR-۰۸	قابلیت حمل	اجرا بدون Docker روی macOS و Linux، فایل docker-compose برای استقرار

۲-۴ نمودار موارد کاربرد

نمودار زیر موارد کاربرد سه نقش را نشان می‌دهد. مشتری همه‌ی توانایی‌های مهمان را به ارث می‌برد و علاوه بر آن قابلیت‌های حساب کاربری و سفارش را دارد. مدیر از راه پنل جداگانه و با احراز هویت JWT کار می‌کند.



شکل ۲-۲: نمودار موارد کاربرد سامانه تک‌شاپ

۲-۵ سناریوهای کاربردی

هر سناریو به صورت یک جدول با بازیگر، پیش‌شرط، جریان اصلی، جریان‌های جایگزین و پس‌شرط توصیف شده است. این سناریوها مبنای آزمون‌های انتهابه‌انتها در فصل ششم هستند.

سناریوی ۱: مرور، جست‌وجو و فیلتر محصولات

جدول ۲-۵: سناریوی مرور و جست‌وجو

بخش	شرح
بازیگر	مهمان یا مشتری
پیش‌شرط	حداقل یک محصول فعال در پایگاه داده وجود دارد.
جریان اصلی	۱) کاربر صفحه‌ی فروشگاه را باز می‌کند؛ ۲) فهرست ۱۲ محصول و فیلترها نمایش داده می‌شود؛ ۳) کاربر برند یا بازه‌ی قیمت را انتخاب می‌کند؛ ۴) نشانی مرورگر با پارامترهای فیلتر به‌روز می‌شود و نتایج جدید می‌آید؛ ۵) کاربر روی یک محصول کلیک می‌کند و صفحه‌ی جزئیات باز می‌شود.
جریان‌های جایگزین	اگر نتیجه‌ای یافت نشود، حالت خالی با دکمه‌ی «پاک کردن فیلترها» نشان داده می‌شود. اگر شماره‌ی صفحه خارج از محدوده باشد، پیام «این صفحه وجود ندارد» می‌آید.

بخش	شرح
پس‌شرط	وضعیت فیلتر در نشانی صفحه ذخیره است؛ بارگذاری مجدد همان نتیجه را نشان می‌دهد.

سناریوی ۲: مدیریت سبد خرید

جدول ۲-۶: سناریوی سبد خرید

بخش	شرح
بازیگر	مهمان یا مشتری
پیش‌شرط	محصول موجود است.
جریان اصلی	(۱) کاربر در صفحه‌ی محصول تعداد را انتخاب و «افزودن به سبد خرید» را می‌زند؛ (۲) سرور سبد را در نشست ذخیره و سبد به‌روز را برمی‌گرداند؛ (۳) شمارنده‌ی سبد در هدر به‌روز می‌شود و پیام «به سبد خرید اضافه شد» نمایش داده می‌شود؛ (۴) در صفحه‌ی سبد کاربر تعداد را کم یا زیاد یا کالا را حذف می‌کند؛ (۵) جمع کل و نوار پیشرفت ارسال رایگان به‌روز می‌شوند.
جریان‌های جایگزین	اگر تعداد از موجودی بیشتر باشد، دکمه‌ی افزایش غیرفعال می‌شود. اگر درخواست با خطا مواجه شود، پیام خطا نشان داده و سبد دست‌نخورده می‌ماند.
پس‌شرط	سبد در نشست (Redis) نگهداری می‌شود و پس از ورود به حساب حفظ می‌شود.

سناریوی ۳: ثبت‌نام و ورود

جدول ۲-۷: سناریوی ثبت‌نام و ورود

بخش	شرح
بازیگر	مهمان
پیش‌شرط	کاربر حساب ندارد.
جریان اصلی	(۱) کاربر فرم ثبت‌نام را پر می‌کند و شرایط را می‌پذیرد؛ (۲) سرور نام کاربری (شروع با @)، ایمیل یکتا و قدرت گذرواژه را بررسی می‌کند؛ (۳) حساب ساخته می‌شود و کاربر به صفحه‌ی ورود می‌رود؛ (۴) با نام کاربری و گذرواژه وارد می‌شود؛ (۵) سرور نشست جدید و توکن CSRF تازه می‌دهد؛ (۶) کاربر به صفحه‌ای که پیش از ورود می‌خواست باز می‌گردد.

بخش	شرح
جریان‌های جایگزین	گذرواژه‌ی نادرست پیام «نام کاربری یا رمز عبور نادرست است» می‌دهد (بدون افشای وجود حساب). پس از ۱۰ تلاش در دقیقه خطای ۴۲۹ برمی‌گردد. پذیرفتن نشدن شرایط، خطای کنار کادر نمایش می‌دهد.
پس‌شرط	کاربر وارد شده و هدر وضعیت حساب را نشان می‌دهد.

سناریوی ۴: ثبت سفارش

جدول ۲-۸: سناریوی ثبت سفارش

بخش	شرح
بازیگر	مشتری
پیش‌شرط	کاربر وارد شده و سبد خالی نیست.
جریان اصلی	۱) کاربر در صفحه‌ی سبد «ادامه و ثبت سفارش» را می‌زند؛ ۲) صفحه‌ی بررسی سفارش آدرس، اقلام و قیمت نهایی را نشان می‌دهد؛ ۳) کاربر «ثبت سفارش و پرداخت» را می‌زند؛ ۴) سرور قفل کاربر را می‌گیرد، سبد را می‌خواند و در یک تراکنش اتمیک سفارش، فاکتور، تراکنش (pending) و اقلام را می‌سازد؛ ۵) سبد پاک و قفل آزاد می‌شود؛ ۶) صفحه‌ی موفقیت کد سفارش را نشان می‌دهد.
جریان‌های جایگزین	اگر آدرس ناقص باشد هشدار با پیوند به صفحه‌ی آدرس نمایش داده می‌شود. اگر کاربر دوبار کلیک کند، درخواست دوم خطای ۴۰۹ می‌گیرد و سفارش تکراری ساخته نمی‌شود. اگر جمع سفارش از سقف مجاز بگذرد، خطای ۴۰۰ برمی‌گردد.
پس‌شرط	سفارش با وضعیت «در انتظار پرداخت» در حساب کاربر دیده می‌شود.

سناریوی ۵: مدیریت پروفایل و آدرس

جدول ۲-۹: سناریوی پروفایل و آدرس

بخش	شرح
بازیگر	مشتری
جریان اصلی	۱) کاربر صفحه‌ی ویرایش اطلاعات را باز می‌کند؛ ۲) مقادیر معتبر (کد ملی ۱۰ رقم، موبایل با ۰۹، کد پستی ۱۰ رقم) را وارد و تصویر را انتخاب می‌کند؛ ۳) سرور ارقام فارسی را به لاتین تبدیل و ذخیره می‌کند؛ ۴) صفحه‌ی پروفایل با پیام موفقیت و نوار کامل‌بودن اطلاعات نمایش داده می‌شود.

بخش	شرح
جریان‌های جایگزین	خالی‌کردن نام یا ایمیل خطای «لطفاً این فیلد را پر کنید» می‌دهد. تصویر بزرگ‌تر از ۲ مگابایت رد می‌شود. تصویر قبلی هنگام جایگزینی از دیسک حذف می‌شود.
پس شرط	داده‌های جدید در پروفایل و صفحه‌ی پرداخت دیده می‌شوند.

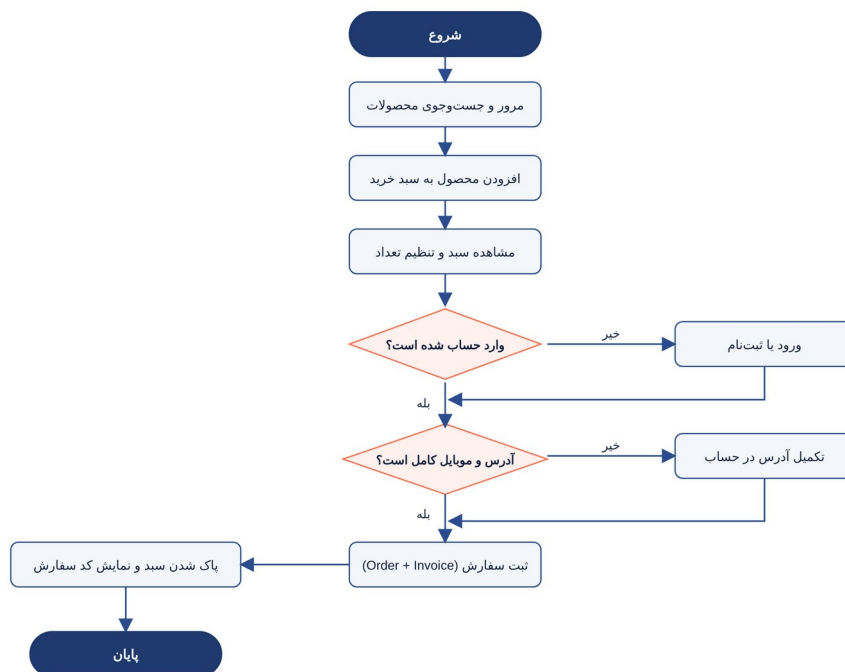
سناریوی ۶: کار مدیر در پنل

جدول ۲-۱۰: سناریوی پنل مدیریت

بخش	شرح
بازیگر	مدیر
جریان اصلی	۱) مدیر در صفحه‌ی ورود پنل نام کاربری و گذرواژه را وارد می‌کند؛ ۲) سرور توکن دسترسی و توکن تازه‌سازی (JWT) می‌دهد؛ ۳) داشبورد شمار سفارش، کاربر، محصول و مدیر و پنج سفارش آخر را نشان می‌دهد؛ ۴) مدیر دسته‌بندی جدید با تصویر می‌سازد یا محصولی را حذف می‌کند؛ ۵) فهرست کاربران و سفارش‌ها را جست‌وجو می‌کند.
جریان‌های جایگزین	کاربر غیرمدیر پس از ورود پیام نبود دسترسی می‌گیرد. اگر توکن دسترسی منقضی شده باشد، توکن تازه‌سازی به‌طور شفاف استفاده می‌شود؛ اگر هر دو نامعتبر باشند، کاربر به صفحه‌ی ورود هدایت می‌شود.
پس شرط	تغییرات بلافاصله در فروشگاه دیده می‌شود.

۶-۲ نمودار فعالیت فرایند خرید

نمودار زیر مسیر کامل یک خرید را از مرور محصول تا نمایش کد سفارش نشان می‌دهد و تصمیم‌های مهم آن، یعنی وضعیت ورود کاربر و کامل‌بودن آدرس، را مشخص می‌کند.

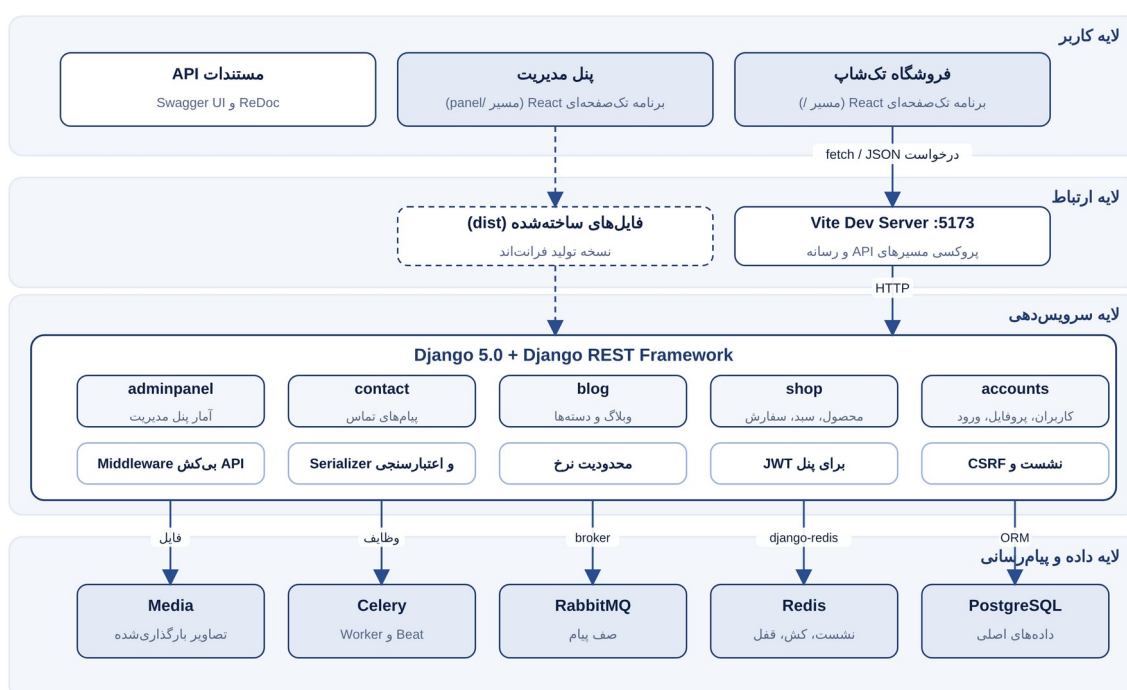


شکل ۲-۳: نمودار فعالیت فرایند خرید

فصل ۳: فناوری‌های به‌کاررفته

۳-۱ معیارهای انتخاب فناوری

فناوری‌ها بر اساس چند معیار انتخاب شدند: بالغ‌بودن و پشتیبانی بلندمدت، وجود مستندات و جامعه‌ی کاربری بزرگ، امکان اجرا بدون Docker روی رایانه‌ی شخصی، سازگاری با زبان فارسی و جهت راست‌به‌چپ، و امکان آزمون خودکار. همچنین پروژه از ابتدا با Python و Django آغاز شده بود و حفظ این پایه، هزینه‌ی بازنویسی را کم می‌کرد.



شکل ۳-۴: نمای کلی پشته‌ی فناوری و لایه‌های سامانه

۳-۲ پشته‌ی سمت سرور

جدول ۳-۱۱: فناوری‌های سمت سرور

فناوری	نسخه	نقش در پروژه
Python	۳/۱۲	زبان برنامه‌نویسی سمت سرور
Django	۵/۰/۴	چارچوب وب: مدل‌ها، ORM، مدیریت، نشست، CSRF
Django REST Framework	۳/۱۵/۱	ساخت Serializer: API، نمای‌های API، محدودیت نرخ

فناوری	نسخه	نقش در پروژه
Simple JWT	۵/۳/۱	احراز هویت پنل مدیریت با توکن دسترسی و تازه‌سازی
drf-yasg	۱/۲۱/۷	تولید مستندات Swagger و ReDoc
django-filter	۲۴/۲	فیلتر پرس‌وجوها در API مدیریتی
django-cors-headers	۴/۴	کنترل مبدهای مجاز
Jazzmin	۲/۶/۱	ظاهر پنل مدیریت پیش‌فرض Django
django-jalali	۶/۲	تاریخ شمسی در مدل‌ها و نمایش
PostgreSQL	۱۶	پایگاه داده‌ی رابطه‌ای اصلی
Redis / django-redis	۵/۴ / ۵/۰/۸	کش، نشست، شمارنده‌ی محدودیت نرخ و قفل سفارش
Celery / django-celery-beat	۲/۶ / ۵/۴	اجرای کارهای زمان‌بندی‌شده (مانند پاک‌سازی پیام‌های تماس)
RabbitMQ	—	صف پیام برای Celery
Pillow	۱۰/۳	پردازش و اعتبارسنجی تصاویر بارگذاری‌شده
pytest / pytest-django	۴/۸ / ۸/۳	آزمون‌های خودکار سمت سرور
Docker Compose	—	استقرار مجموعه‌ی سرویس‌ها

Django REST Framework و Django

Django یک چارچوب «باتری‌همراه» است که ORM، سامانه‌ی مهاجرت پایگاه داده، مدیریت کاربران و نشست، محافظت CSRF و پنل مدیریت را آماده ارائه می‌کند. این ویژگی‌ها برای یک فروشگاه که به اعتبارسنجی دقیق و امنیت نیاز دارد مناسب است. Django REST Framework (DRF) روی Django قرار می‌گیرد و ساخت API مبتنی بر JSON را با Serializer، نمای‌های کلاس‌محور، مجوزها و محدودیت نرخ ساده می‌کند. در این پروژه DRF هم برای API عمومی فروشگاه (با نشست) و هم برای API مدیریتی (با JWT) استفاده شده است.

RabbitMQ، PostgreSQL و Redis

PostgreSQL به دلیل تراکنش‌های قابل اتکا (ACID)، انواع داده‌ی غنی و عملکرد خوب برای داده‌های رابطه‌ای فروشگاه (کاربر، محصول، سفارش) انتخاب شد. Redis به عنوان انبار درون‌حافظه‌ی سریع برای نشست‌ها، شمارنده‌های محدودیت نرخ و قفل کوتاه‌مدت کاربر هنگام ثبت سفارش به کار می‌رود. RabbitMQ و Celery برای کارهایی که نباید در چرخه‌ی درخواست انجام شوند (مانند پاک‌سازی دوره‌ای) در معماری پیش‌بینی شده‌اند.

۳-۳ پشته‌ی سمت کاربر

جدول ۳-۱۲: فناوری‌های سمت کاربر

فناوری	نسخه	نقش در پروژه
React	۱۸/۳	کتابخانه‌ی ساخت رابط کاربری مبتنی بر مؤلفه
Vite	۵/۴	ابزار توسعه و بسته‌بندی با سرور توسعه‌ی سریع و پروکسی API
React Router	۶/۳۰	مسیریابی سمت کاربر و مسیرهای محافظت‌شده
lucide-react	۱/۵۳	مجموعه‌ی آیکون‌های SVG
Vazirmatn	۳۳	قلم فارسی آزاد (SIL OFL) با ارقام فارسی؛ جایگزین ایران‌یکان تا زمان تهیه‌ی پروانه‌ی آن
CSS Custom Properties	—	توکن‌های طراحی: رنگ، فاصله، شعاع، سایه و قلم
Playwright	—	آزمون انتهابه‌انتها و گرفتن تصویر از رابط

Vite و React

React بر پایه‌ی مؤلفه‌های قابل ترکیب کار می‌کند و وضعیت رابط را با توابع و Hookها مدیریت می‌کند. در این پروژه از Context برای سه وضعیت سراسری (ورود، سبد خرید، پیام‌های موقت) استفاده شده و هر صفحه با React.lazy به صورت جداگانه بارگذاری می‌شود. Vite به جای بسته‌بند سنتی، در توسعه از ماژول‌های بومی مرورگر استفاده می‌کند و بنابراین شروع و به‌روزرسانی آن بسیار سریع است؛ همچنین پروکسی داخلی آن مرورگر را مجبور به کار با «یک مبدأ» می‌کند و مشکل CORS و کوکی نشست را از میان می‌برد.

سیستم طراحی و قلم

به جای وابستگی به یک چارچوب CSS آماده، یک کیت طراحی اختصاصی ساخته شد: مقیاس رنگ سورمه‌ای به عنوان رنگ برند، رنگ کورال برای تأکید، و مجموعه‌ای از توکن‌های فاصله و سایه. قلم Vazirmatn از راه بسته‌ی npm به پروژه اضافه شده و سازوکاری آماده است تا در صورت افزودن فایل‌های قلم ایران‌یکان، بدون تغییر دیگری جایگزین شود.

۳-۴ ابزارهای توسعه و کیفیت

جدول ۳-۱۳: ابزارهای توسعه و کیفیت

ابزار	کاربرد
Git و GitHub	کنترل نسخه، شاخه‌ی ویژگی (feature branch) و تاریخچه‌ی تغییرات
pytest	۱۷۳ آزمون واحد و یکپارچه‌ی سمت سرور
Playwright (Chromium)	آزمون‌های انتها به انتها، گرفتن تصویر و بررسی واکنش‌گرایی
اسکرپیت بررسی صفحه	سنجش سرریز افقی، خطای کنسول، تصویر خراب، برچسب فرم‌ها و تباین رنگ
Swagger / ReDoc	مستندات زنده و آزمایش دستی API
Claude Code	دستیار هوش مصنوعی برای تولید، بازمینی و آزمون کد؛ خروجی‌ها به صورت دستی اجرا و بررسی شدند

۳-۵ مقایسه‌ی گزینه‌ها و دلیل انتخاب

جدول ۳-۱۴: گزینه‌های بررسی‌شده و تصمیم نهایی

حوزه	گزینه‌ی انتخابی	گزینه‌ی دیگر	دلیل انتخاب
رابط کاربری	React (SPA)	قالب‌های Django	تجربه‌ی روان‌تر، جداسازی API، بازاستفاده در پنل مدیریت
بسته‌بند	Vite	Create React App / Webpack	شروع سریع‌تر، پیکربندی کمتر، نگهداری فعال
احراز هویت فروشگاه	نشست + CSRF	JWT در localStorage	کوکی HttpOnly امن‌تر است و سبب مهمان به نشست وابسته است
احراز هویت پنل	JWT	نشست	پنل مستقل و بدون وابستگی به کوکی فروشگاه
ذخیره‌ی نشست	Redis	پایگاه داده	سرعت بالا و انقضای خودکار
استایل	CSS سفارشی با توکن	Bootstrap	کنترل کامل ظاهر، حجم کمتر، رنگ‌بندی یکدست
قلم	Vazirmatn	ایران‌یکان	ایران‌یکان مجوزی است و فایل آن در مخزن نیست
آیکون	lucide-react	Font Awesome	SVG سبک، حذف کد بلااستفاده (tree-shaking) و ظاهر یکدست

فصل ۴: طراحی و معماری سیستم

۴-۱ معماری کلی

سامانه از چهار لایه تشکیل شده است (شکل ۳-۱). مرورگر دو برنامه‌ی React را اجرا می‌کند: ویتترین فروشگاه در مسیر ریشه و پنل مدیریت در مسیر panel/. در محیط توسعه، سرور Vite درخواست‌های مربوط به API و رسانه را به Django هدایت می‌کند تا مرورگر فقط با یک مبدأ کار کند؛ در نسخه‌ی تولید فایل‌های ساخته‌شده (dist) از همان مبدأ Django سرو می‌شوند. سرور Django با DRF داده‌ها را از PostgreSQL می‌خواند و می‌نویسد و از Redis برای نشست و قفل بهره می‌برد.

اصل اصلی معماری «جداسازی دغدغه‌ها» است: Django فقط داده و قواعد کسب‌وکار را مدیریت می‌کند و هیچ HTML فروشگاه‌ی تولید نمی‌کند؛ React فقط نمایش و تعامل را بر عهده دارد و هیچ قاعده‌ی قیمت یا سفارشی را خودش تصمیم نمی‌گیرد. محاسبه‌ی قیمت نهایی، بررسی موجودی و ساخت سفارش همگی در سرور انجام می‌شود.

۴-۲ معماری سمت سرور

پروژه‌ی Django به چند «اپ» با مسئولیت مشخص تقسیم شده است. هر اپ مدل‌ها، Serializerها، نمای‌های API و آزمون‌های خود را دارد.

جدول ۴-۱۵: اپ‌های Django و مسئولیت هر کدام

اپ	مسئولیت	نمونه‌ی محتوا
accounts	کاربران، پروفایل، ورود/ثبت‌نام مشتری و API کاربران مدیر	CustomUser، CustomProfileModel، customer_views
shop	کاتالوگ، سفارش، فاکتور، تراکنش و API عمومی فروشگاه	Product، Order، checkout_views، pricing
cart	منطق سبد خرید مبتنی بر نشست	کلاس Cart و lines()
blog	مقالات و دسته‌بندی وبلاگ	Blogs، Category_blog
contact	پیام‌های فرم تماس	Contact
adminpanel	API آمار داشبورد	user-count، new-order، product-count
shopproject	تنظیمات، مسیرها، امنیت، محدودیت نرخ و میان‌افزار	security.py، throttles.py، middleware.py

Order وصل است تا در آینده بتوان چند تلاش پرداخت را برای یک سفارش ثبت کرد. سوم آن‌که مقادیر پولی با DecimalField (و نه اعداد اعشاری) نگهداری می‌شوند و درصد تخفیف با اعتبارسنج بین صفر و صد محدود شده است.

جدول ۴-۱۶: موجودیت‌های اصلی و نقش آن‌ها

موجودیت	توضیح	رابطه‌های مهم
CustomUser	حساب کاربری با نام کاربری یکتا و uuid	ابه‌ا با پروفایل؛ ابه‌N با سفارش
CustomProfileModel	کد ملی، آدرس، موبایل، سن، تصویر و شبا	ابه‌ا با کاربر
Category / Brand	دسته‌بندی و برند کالا با نامک (slug)	برند چندبه‌چند با دسته
Product	کالا با قیمت، تخفیف، موجودی، مشخصات و ۵ تصویر	ابه‌N با دسته، برند و Info
Order / OrderItem	سفارش و اقلام آن با قیمت لحظه‌ای خرید	Product و Order به OrderItem
Invoice / Transaction	فاکتور سفارش و تراکنش با وضعیت pending/completed/failed	Transaction به Invoice؛ Invoice به Order
Comment	دیدگاه و امتیاز کاربر برای محصول	ابه‌N با کاربر و محصول
Blogs / Category_blog	مقاله و دسته‌بندی آن	Blogs به کاربر و دسته
Contact	پیام فرم تماس	مستقل

۴-۴ طراحی API

API دو خانواده دارد: خانوادگی عمومی و مشتری که با نشست و CSRF کار می‌کند و رابط فروشگاه از آن استفاده می‌کند، و خانوادگی مدیریتی که با JWT محافظت می‌شود و پنل مدیریت و مستندات از آن بهره می‌برند. همه‌ی پاسخ‌ها JSON هستند و خطاهای اعتبارسنجی به صورت دیکشنری «فیلد ← پیام» برگردانده می‌شوند تا رابط بتواند پیام را کنار همان فیلد نشان دهد.

جدول ۴-۱۷: API عمومی فروشگاه (پیشوند /shop/api/v1/public/)

مسیر	روش	کارکرد
/categories/ ، brands	GET	فهرست دسته‌بندی‌ها و برندها
/products	GET	فهرست با فیلتر، مرتب‌سازی و صفحه‌بندی
/products/filters	GET	گزینه‌های فیلتر (برند، رنگ، بازه‌ی قیمت)

مسیر	روش	کارکرد
/products/{slug}	GET	جزئیات محصول و گالری تصویر
/cart	GET، POST	خواندن و افزودن/تغییر تعداد سبد
/cart/{id}	DELETE	حذف یک کالا از سبد
/checkout	GET، POST	خلاصه‌ی پرداخت و ثبت سفارش
blog/ ، blog/categories/ ، /blog/{slug}	GET	مقالات وبلاگ
/contact	POST	ارسال پیام تماس (۱۰ در ساعت)
/session	GET	وضعیت ورود کاربر

جدول ۴-۱۸: API مشتری (پیشوند /accounts/api/v1/customer/)

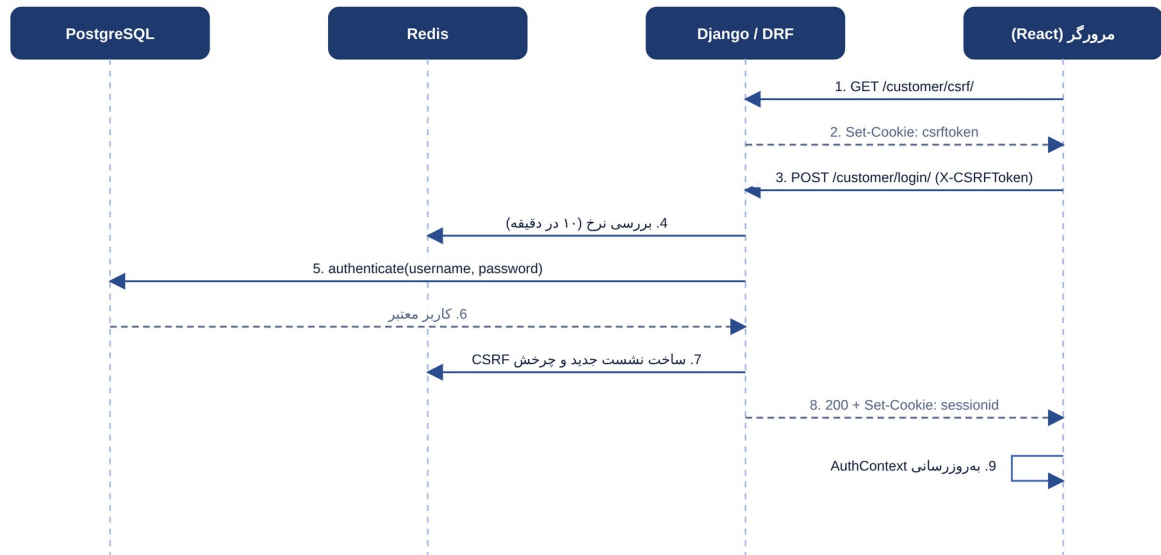
مسیر	روش	کارکرد
/csrf	GET	تنظیم کوکی csrftoken
/register	POST	ثبت‌نام (۱۰ در ساعت)
/login/ ، logout	POST	ورود (۱۰ در دقیقه) و خروج
/profile	GET، PATCH	پروفایل و ویرایش (چندبخشی با تصویر)
/password	POST	تغییر گذرواژه
/address	GET، PUT	آدرس تحویل
orders/ ، orders/latest/ ، /orders/{id}	GET	فهرست، آخرین و جزئیات سفارش

API مدیریتی شامل مسیرهای فهرست، جزئیات، ایجاد، ویرایش و حذف برای دسته‌بندی، برند، محصول، سفارش، قلم سفارش، فاکتور و تراکنش، همچنین کاربران و پروفایل‌ها، مقالات و پیام‌های تماس است (حدود ۵۰ مسیر). ورود مدیر در /accounts/api/v1/login/ انجام می‌شود و توکن‌ها از /api/token/refresh تازه می‌شوند. پیوست الف فهرست کامل را می‌آورد.

۴-۵ نمودارهای توالی

۴-۵-۱ ورود کاربر

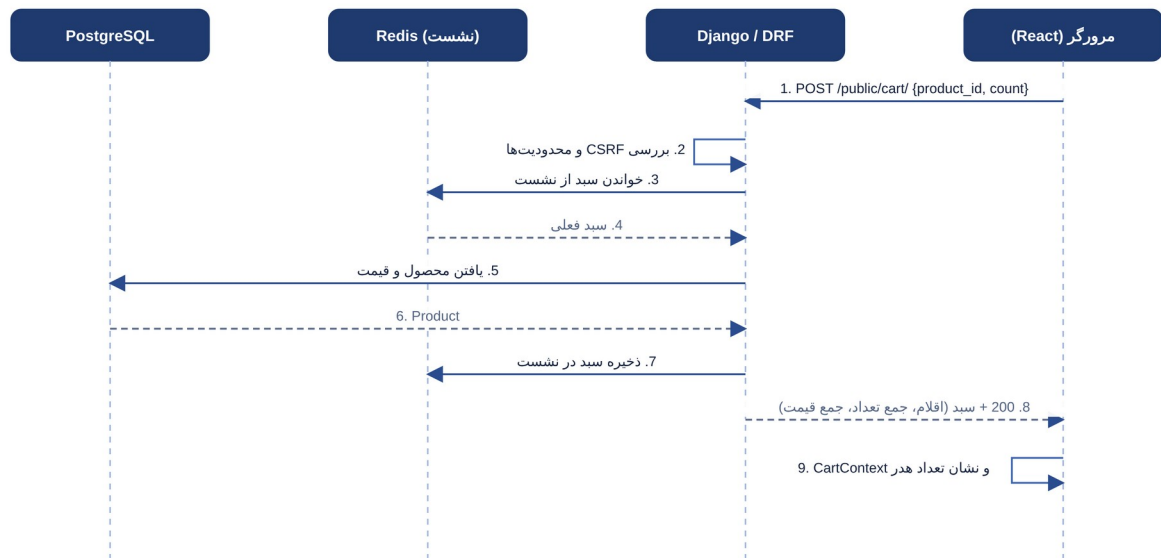
ورود در چهار گام انجام می‌شود: مرورگر ابتدا کوکی csrftoken را می‌گیرد، سپس درخواست ورود را با هدر X-CSRFToken می‌فرستد. سرور پیش از احراز هویت، محدودیت نرخ را از Redis می‌خواند. پس از موفقیت، نشست جدید ساخته و توکن CSRF چرخانده می‌شود تا نشست قدیمی قابل سوءاستفاده نباشد.



شکل ۴-۶: نمودار توالی ورود کاربر

۴-۵-۲ افزودن به سبد خرید

سبد خرید در نشست کاربر (Redis) نگهداری می‌شود و برای مهمان نیز کار می‌کند. هر درخواست محصول را از پایگاه داده می‌خواند تا قیمت و تخفیف همیشه از سرور محاسبه شود و رابط هرگز قیمت را تعیین نکند.

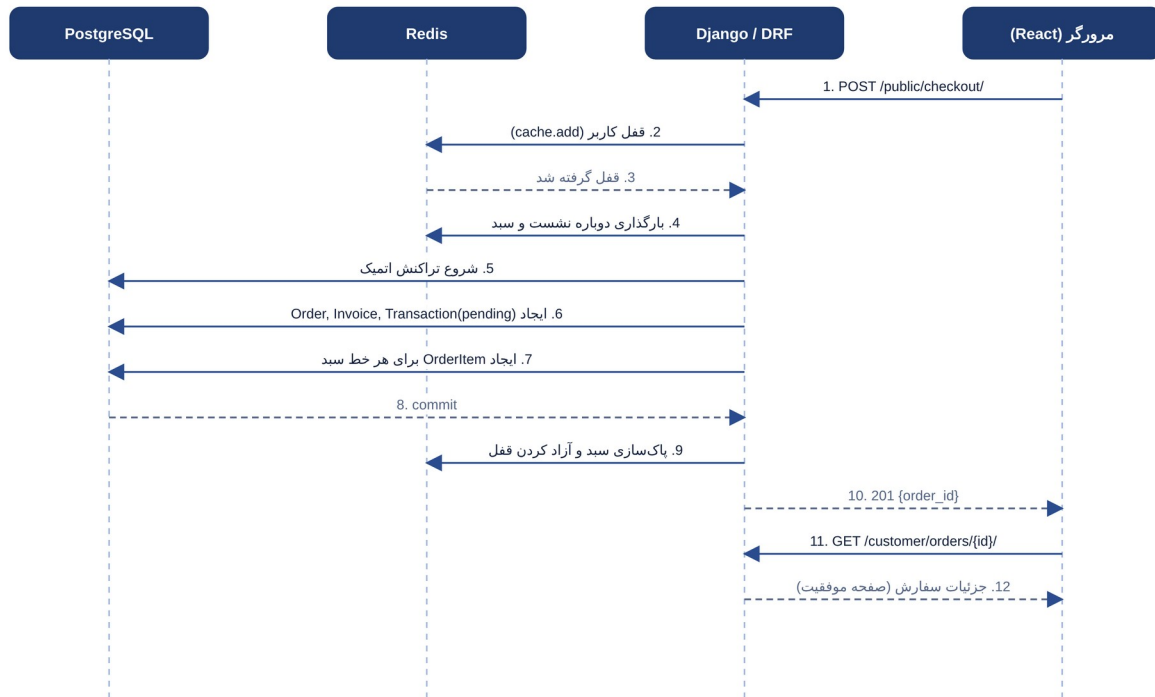


شکل ۴-۷: نمودار توالی افزودن کالا به سبد

۴-۵-۳ ثبت سفارش

ثبت سفارش حساس‌ترین بخش سامانه است. سرور ابتدا با `cache.add` یک قفل ۳۰ ثانیه‌ای برای کاربر می‌گیرد؛ اگر قفل موجود باشد، درخواست دوم با خطای ۴۰۹ رد می‌شود و دوبار کلیک سفارش تکراری

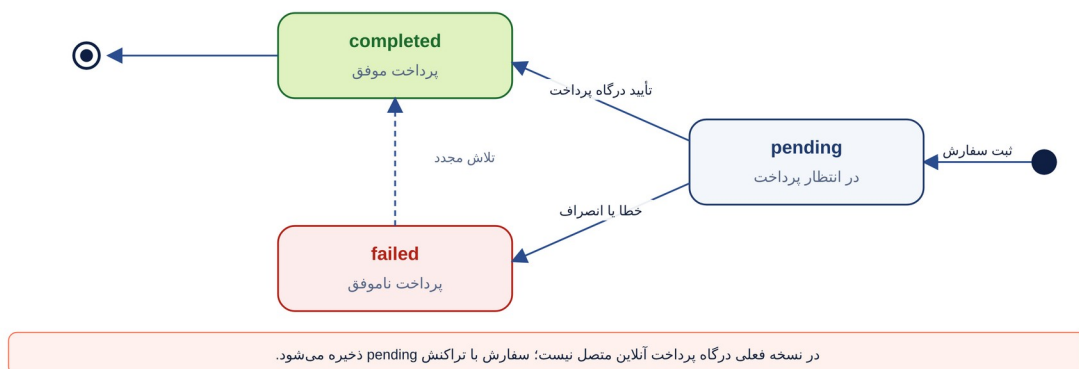
نمی‌سازد. پس از آن نشست دوباره بارگذاری می‌شود تا سبد تازه خوانده شود و در یک تراکنش اتمیک سفارش، فاکتور، تراکنش و اقلام ساخته می‌شوند؛ اگر هر مرحله خطا بدهد، هیچ‌چیز ذخیره نمی‌شود.



شکل ۴-۸: نمودار توالی ثبت سفارش

۴-۶ وضعیت سفارش

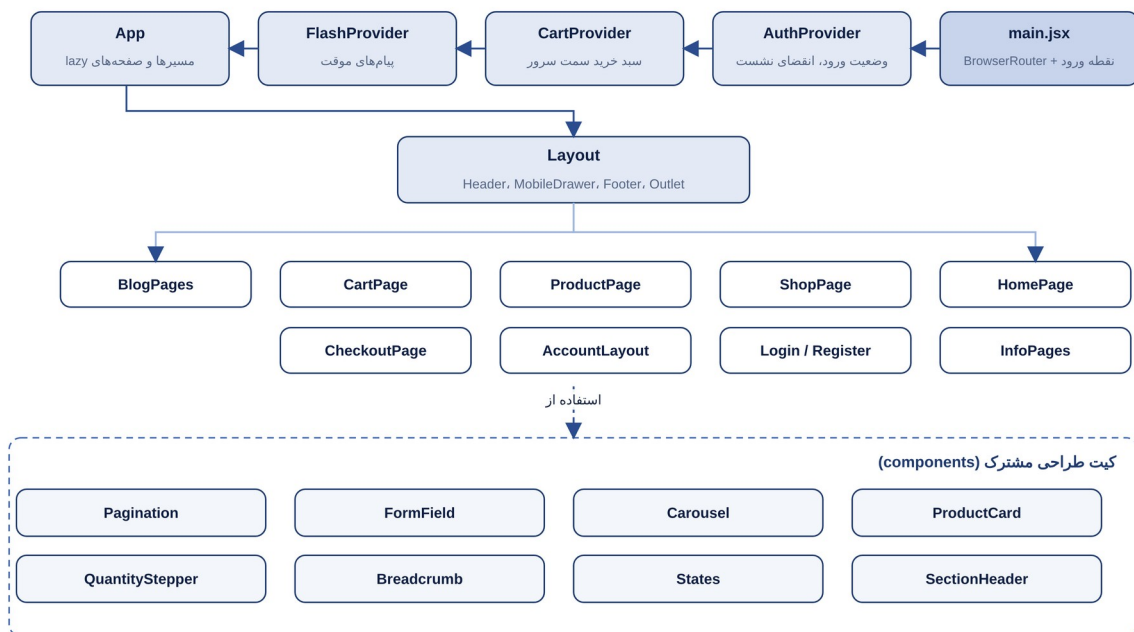
هر سفارش پس از ثبت یک تراکنش با وضعیت pending دارد. در نسخه‌ی فعلی درگاه پرداخت متصل نیست، اما مدل حالت‌های completed و failed را پشتیبانی می‌کند تا اتصال درگاه در آینده نیازی به تغییر پایگاه داده نداشته باشد.



شکل ۴-۹: نمودار حالت سفارش و تراکنش

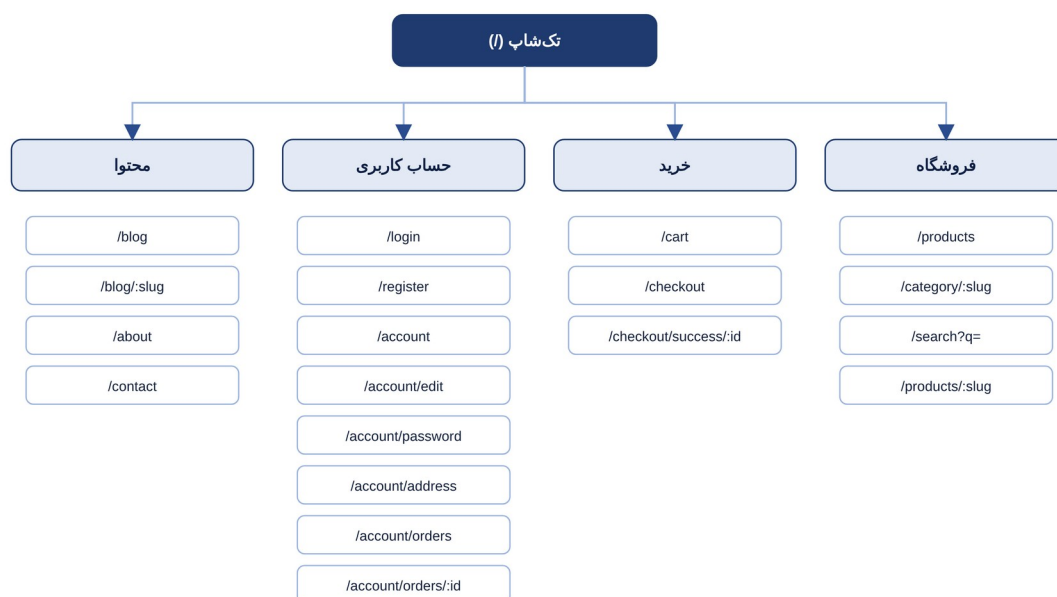
۴-۷ معماری سمت کاربر

ساختار برنامه‌ی React در شکل ۴-۶ آمده است. نقطه‌ی ورود سه Provider را تو در تو می‌کند: AuthProvider وضعیت ورود، انقضای نشست و نگره می‌دارد و هنگام انقضای نشست (پاسخ ۴۰۳ از API مشتری) رویداد خروج می‌فرستد؛ CartProvider سبد سمت سرور را همگام می‌کند و پس از ورود و خروج دوباره می‌خواند؛ FlashProvider پیام‌های موقت را نشان می‌دهد. مسیریابی با React Router انجام می‌شود و صفحه‌های نیازمند ورود پشت RequireAuth قرار دارند.



شکل ۴-۱۰: ساختار مؤلفه‌های برنامه‌ی React

لایه‌ی ارتباط با سرور (api/client.js) یک تابع fetch است که کوکی نشست را می‌فرستد، توکن CSRF را در هدر X-CSRFToken قرار می‌دهد و اگر سرور به دلیل کهنه‌شدن توکن خطا بدهد، یک بار تلاش را تکرار می‌کند. خطاها به کلاس **ApiError** با پیام فارسی تبدیل می‌شوند. هر صفحه با **React.lazy** بارگذاری می‌شود و مرور صفحه‌های پنهان در مرورگر را سبک نگه می‌دارد.



شکل ۴-۱۱: نقشه‌ی صفحه‌های وب‌ترین فروشگاه

۴-۸ طراحی رابط کاربری

رابط بر اساس چند اصل طراحی شد: رنگ سورمه‌ای برند و کورال فقط برای تأکید (نشان تخفیف و شمارنده‌ی سبد)، سطوح روشن با کارت‌های گوشه‌گرد، فاصله‌گذاری بر پایه‌ی ۴ پیکسل، و جهت راست‌به‌چپ با ویژگی‌های منطقی CSS (مثل margin-inline-start) تا چیدمان بدون تغییر کد جهت را رعایت کند. هر داده‌ی ناهمگام سه حالت دارد: بارگذاری (اسکلت)، خطا (با تلاش دوباره) و خالی.



شکل ۴-۱۲: پالت رنگ سامانه (مقیاس سورمه‌ای، کورال و رنگ‌های وضعیت)

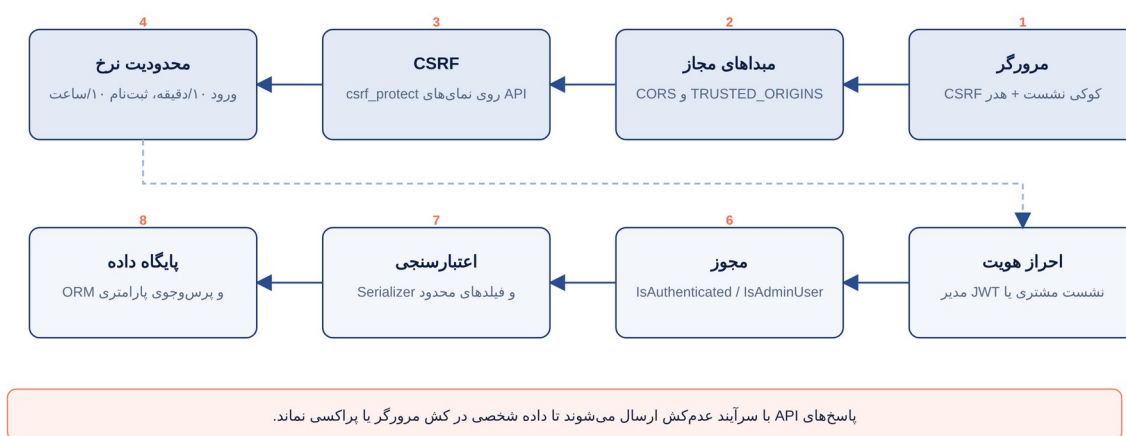
جدول ۴-۱۹: توکن‌های اصلی طراحی

توکن	مقدار	کاربرد
navy-۷۰۰--	#1f3a6e	رنگ برند، دکمه‌ها و قیمت
navy-۹۰۰--	#0f1f44	عنوان‌ها و پس‌زمینه‌ی تیره

توکن	مقدار	کاربرد
coral-۵۰۰--	ff۶b۴a#	نشان تخفیف و شمارنده‌ی سبد (متن تیره روی آن)
coral-۷۰۰--	c۹۳f۱f#	متن یا دکمه‌ی کورال با متن سفید
color-muted--	#۵۶۶۶۸۶	متن ثانویه با تباین ۵/۸ به ۱ روی سفید
radius-lg--	۱۶ پیکسل	گوشه‌ی کارت‌ها
space-۴--	rem ۱	فاصله‌ی پایه
font-main--	IRANYekan, Vazirmatn	قلم همه‌ی صفحه‌ها (حتی input و button)

۹-۴ طراحی امنیت

امنیت در چند لایه‌ی پشت‌سرهم اعمال می‌شود (شکل ۴-۹). یک درخواست پیش از رسیدن به پایگاه داده از مبدهای مجاز، بررسی CSRF، محدودیت نرخ، احراز هویت، مجوز و اعتبارسنجی Serializer عبور می‌کند.



شکل ۴-۱۳: لایه‌های امنیتی عبور درخواست

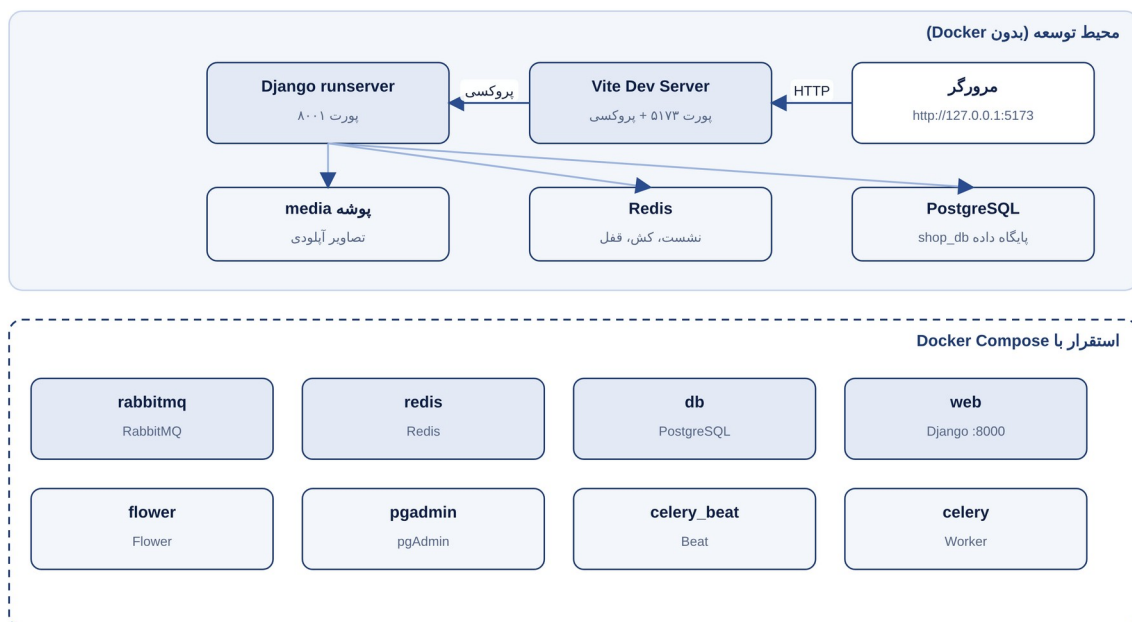
جدول ۴-۲۰: اقدامات امنیتی و تهدیدی که پوشش می‌دهند

اقدام	تهدید	پیاده‌سازی
CSRF روی همه‌ی نمای‌های تغییردهنده	جعل درخواست بین‌سایتی	CsrfProtectedMixin و هدر X-CSRFToken
محدودیت نرخ	حداکثر گذرواژه و ثبت‌نام انبوه	ورود ۱۰ در دقیقه، ثبت‌نام و تماس ۱۰ در ساعت؛ NUM_PROXIES برای جلوگیری از جعل X-Forwarded-For
چرخش نشست	تثبیت نشست	ساخت نشست و CSRF جدید پس از ورود

اقدام	تهدید	پیاده‌سازی
نام کاربری امن	نام‌های شبیه‌ساز و نویسه‌های نامرئی	الگوی @ + حروف انگلیسی، رقم، _ و .
اعتبارسنجی ورودی	داده‌ی نامعتبر، سرریز	سقف قیمت، محدوده‌ی تخفیف ۰ تا ۱۰۰، حجم تصویر ۲ مگابایت
SECRET_KEY از محیط	جعل نشست و توکن	نبود کلید پیش‌فرض خارج از DEBUG و آزمون
سرآیند عدم‌کش	نشست داده‌ی شخصی در کش	NoCacheApiMiddleware
قفل ثبت سفارش	سفارش تکراری	cache.add با انقضای ۳۰ ثانیه و آزادسازی در finally

۱۰-۴ استقرار

در توسعه، Django روی درگاه ۸۰۰۱ و Vite روی ۵۱۷۳ اجرا می‌شوند و PostgreSQL و Redis روی رایانه‌ی محلی هستند (بدون Docker). برای استقرار، فایل docker-compose.yml سرویس‌های web، db، redis، rabbitmq، celery، celery_beat، pgadmin و flower را تعریف می‌کند. نسخه‌ی ساخته‌شده‌ی فرانت‌اند (پوشه‌ی dist) باید از همان مبدأ Django سرو شود؛ این بخش در نسخه‌ی فعلی به‌صورت دستی انجام می‌شود.



شکل ۴-۱۴: نمودار استقرار در محیط توسعه و Docker Compose

فصل ۵: پیاده‌سازی

۵-۱ ساختار پروژه

مخزن پروژه در یک پوشه‌ی ریشه شامل سه بخش اصلی است: shop (سرور Django)، frontend (برنامه‌های React) و docs/scripts (مستندات و ابزارهای تولید داده‌ی نمونه). ساختار ساده‌شده‌ی آن در ادامه آمده است.

ساختار پوشه‌های پروژه

```
shop/
  shopproject/      security.py, throttles.py, middleware.py
                    مسیریات، مسیرها
  accounts/         کاربران مدیر API مشتری و API، کاربر، پروفایل
  shop/             pricing.py, seed ها عمومی API، کاتالوگ، سفارش
  cart/             مبتنی بر نشست Cart کلاس
  blog/ contact/ adminpanel/
  static/assets/img/ لوگو، تصویرسازی‌های محصول و جلد مقاله‌ها
frontend/
  index.html panel/index.html
  src/shared/       brand.js, palette.css, fonts.css, useApi.js
  src/storefront/   api/ auth/ cart/ components/ pages/ styles/
  src/admin/        api/ auth/ layout/ pages/ styles/
scripts/           generate_demo_art.py, generate_blog_covers.py
docs/              و این گزارش design-colors.md
```

مجموع کد نوشته‌شده (بدون مهاجرت‌ها و پکیج‌های نصب‌شده) حدود ۸,۶۰۰ خط Python، ۷,۹۰۰ خط JavaScript/JSP و ۸,۱۰۰ خط CSS است و مخزن بیش از ۹۰ کامیت دارد.

۵-۲ نکات کلیدی پیاده‌سازی سمت سرور

۵-۲-۱ محافظت CSRF برای همه‌ی نمای‌ها

DRF بررسی CSRF را فقط برای درخواست‌های احراز هویت‌شده با نشست انجام می‌دهد، در حالی که ورود، ثبت‌نام و سبد مهمان بدون احراز هویت هستند. برای بستن این شکاف، یک mixin ساخته شد که بررسی Django را دوباره روی متد dispatch اعمال می‌کند:

mixin محافظت CSRF (shopproject/security.py)

```
class CsrfProtectedMixin:
    @method_decorator(csrf_protect)
    def dispatch(self, request, *args, **kwargs):
        return super().dispatch(request, *args, **kwargs)
```

۵-۲-۲ محدودیت نرخ

محدودیت‌های نرخ (shopproject/throttles.py)

```
class LoginThrottle(AnonRateThrottle):
    scope = "customer_login"
    rate = "10/min"

class RegisterThrottle(AnonRateThrottle):
    scope = "customer_register"
    rate = "10/hour"
```

در بازبینی امنیتی معلوم شد که بدون تنظیم DRF، NUM_PROXIES، هدر X-Forwarded-For را که کاربر می‌فرستد باور می‌کند و می‌توان با تغییر آن محدودیت را دور زد. بنابراین این مقدار از متغیر محیطی خوانده می‌شود و در آزمون، جعل هدر بی‌اثر بودنش تأیید شد.

۵-۲-۳ ثبت سفارش بدون تکرار

منطق ثبت سفارش در یک تابع جدا قرار دارد و ترتیب مراحل آن ثابت است: گرفتن قفل، بارگذاری دوباره‌ی نشست، محاسبه‌ی خطوط سبد، گرد کردن مبلغ‌ها با ROUND_HALF_UP، بررسی سقف مجاز (۹۹۹,۹۹۹,۹۹۹)، تراکنش اتمیک و پاک‌سازی سبد. قفل همیشه در بلوک finally آزاد می‌شود تا خطای میانی کاربر را قفل نکند.

قفل و آزادسازی در ثبت سفارش (ساده‌شده)

```
def acquire_checkout_lock(user_id):
    return cache.add(f"checkout-lock-{user_id}", "1", CHECKOUT_LOCK_SECONDS)

def release_checkout_lock(user_id):
    cache.delete(f"checkout-lock-{user_id}")

# in post(): 409 if the lock is taken
try:
    order = place_order(request) # reload session, build lines,
finally:                         # then one atomic block
    release_checkout_lock(user.id)
```

۵-۲-۴ سبد خرید مبتنی بر نشست

کلاس Cart سبد را در کلید ثابتی از نشست نگه می‌دارد. خواندن سبد هیچ‌چیز در نشست نمی‌نویسد، تا بازدید ساده‌ی مهمان‌ها یا ربات‌ها هزاران نشست بی‌مصرف در Redis نسازد. متد lines() فهرستی از دیکشنری‌ها با قیمت واحد پس از تخفیف و جمع هر ردیف می‌دهد و صفحه‌ی سبد، صفحه‌ی پرداخت و ثبت سفارش همگی از همین یک منبع می‌خوانند.

۳-۵ نکات کلیدی پیاده‌سازی سمت کاربر

۱-۳-۵ حالت فیلتر در نشانی صفحه

صفحه‌ی فروشگاه همه‌ی فیلترها، مرتب‌سازی و شماره‌ی صفحه را در پارامترهای نشانی نگه می‌دارد. بنابراین بارگذاری مجدد، دکمه‌ی برگشت مرورگر و اشتراک‌گذاری پیوند همگی رفتار درست دارند. هنگام تغییر فیلتر، صفحه به ۱ باز می‌گردد و هنگام تغییر صفحه، نمایش به بالای نتایج می‌رود.

۲-۳-۵ اسلایدر بر پایه‌ی CSS scroll-snap

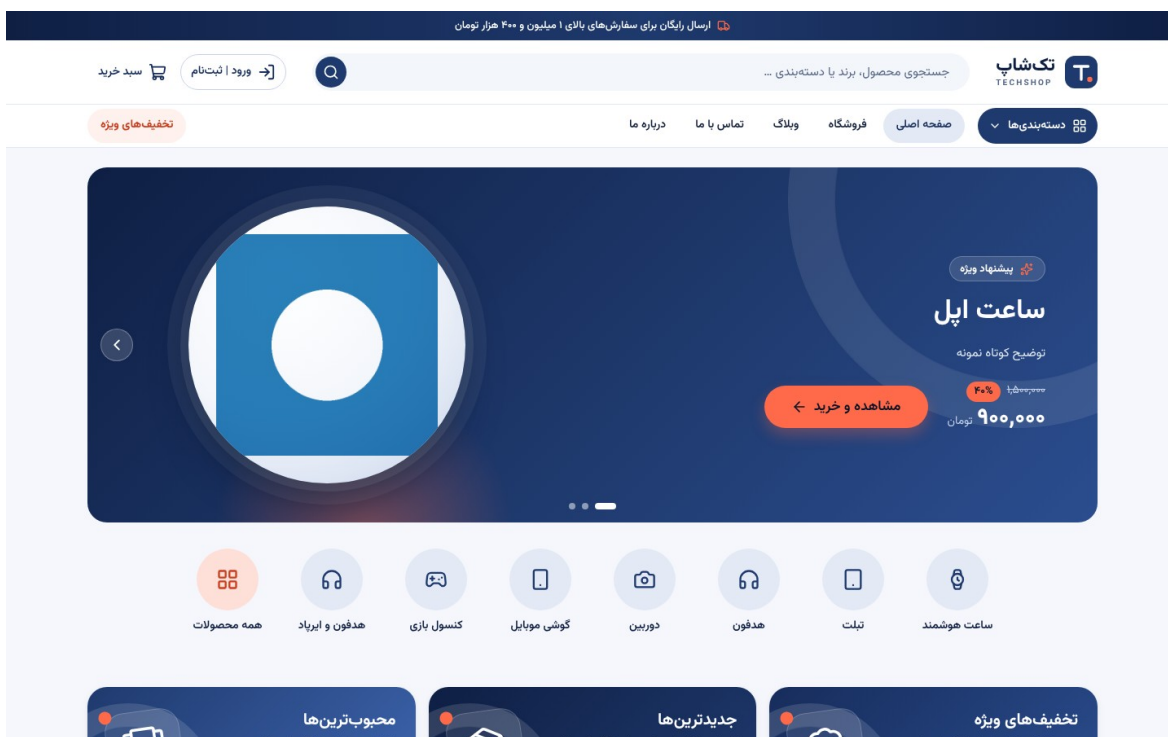
اسلایدرهای صفحه‌ی خانه به‌جای کتابخانه‌ی جاوااسکریپتی، از ویژگی scroll-snap مرورگر استفاده می‌کنند؛ بنابراین کشیدن با انگشت، چرخ ماوس و صفحه‌کلید به‌صورت بومی کار می‌کنند. دکمه‌ها فقط scrollBy را صدا می‌زنند و جهت راست‌به‌چپ (که مقدار scrollLeft را منفی می‌کند) در یک تابع کوچک جبران شده است. نمایش خودکار در صورت فعال‌بودن «کاهش حرکت» سیستم‌عامل متوقف می‌شود.

۳-۳-۵ هماهنگی وضعیت ورود و سبد

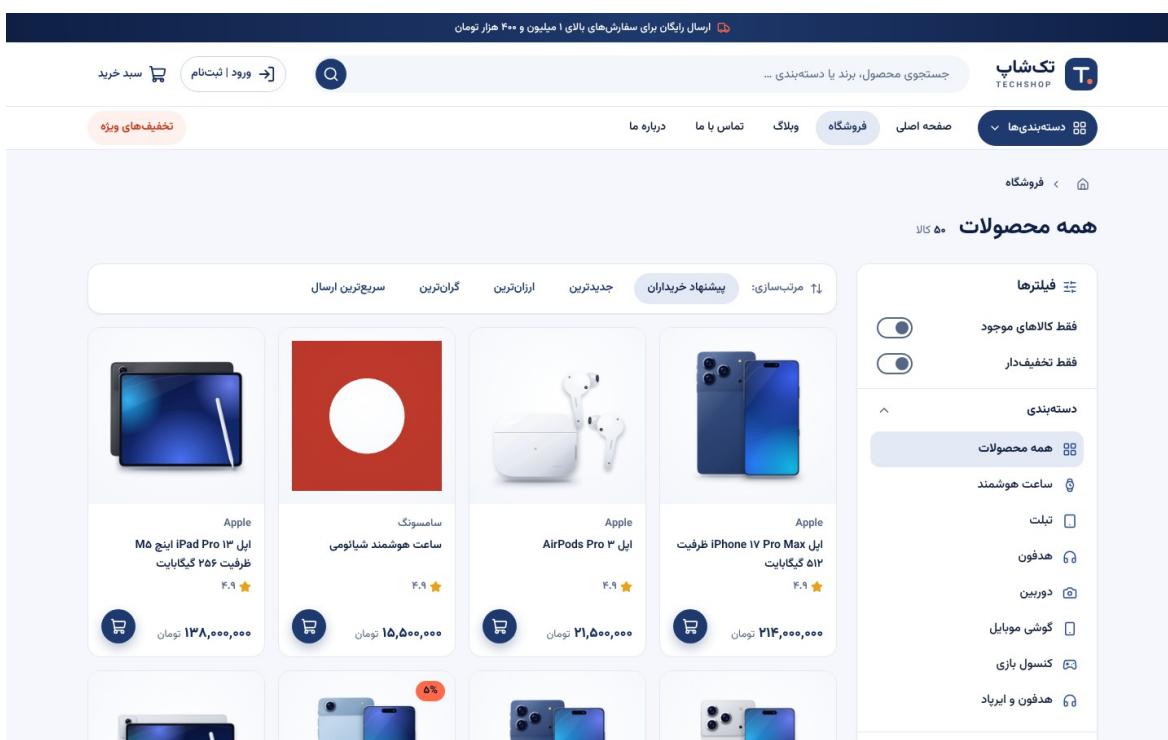
AuthProvider رویداد سفارشی «انقضای نشست» را گوش می‌دهد؛ هرگاه یکی از API‌های مشتری بگوید کاربر شناخته نمی‌شود، رابط به حالت مهمان برمی‌گردد و مسیرهای محافظت‌شده به صفحه‌ی ورود می‌روند. CartProvider با هر تغییر «نسخه‌ی نشست» سبد را دوباره از سرور می‌خواند تا پس از ورود و خروج سبد درست نمایش داده شود.

۴-۵ تصاویر محیط کاربری

شکل‌های این بخش نمایی از محیط واقعی برنامه را نشان می‌دهند. پیکربندی تصویرها پس از اجرای برنامه با داده‌ی نمونه‌ی ۴۳ محصول گرفته شده است. تصویر محصولات تصویرسازی‌های نمایشی هستند، نه عکس رسمی.



شکل ۵-۱۵: صفحه اصلی در نسخه دسکتاپ



شکل ۵-۱۶: فروشگاه با پنل فیلتر، مرتب‌سازی و کارت‌های محصول

ارسال رایگان برای سفارش‌های بالای ۱ میلیون و ۴۰۰ هزار تومان

سبد خرید

ورود | ثبت‌نام

جستجوی محصول، برند یا دسته‌بندی ...

تک‌شاپ
TECHSHOP

دسته‌بندی‌ها

صفحه اصلی

فروشگاه

وبلاگ

تماس با ما

درباره ما

تخفیف‌های ویژه

گوشی موبایل

اپل iPhone ۱۷ Pro Max ظرفیت ۵۱۲ گیگابایت

۲۱۴,۰۰۰,۰۰۰ تومان

زمان ارسال: ۳ روز

تعداد

+

۱

-

حد اکثر ۸ عدد

افزودن به سبد خرید

ضمانت اصالت کالا

۷ روز فرصت بازگشت

سیستم‌عامل

IOS ۱۶

رنگ

آبی سرمه‌ای

قابلیت

Vapor chamber

فناوری

A۱۹ Pro / ۵G

بلوتوث

دارد

رزولوشن دوربین

۴۸ مگاپیکسل

۴.۹

امتياز کاربران از ۱۰

✓ موجود

نمایشگر ۶/۹ اینچی، A۱۹ Pro و سه دوربین ۴۸ مگاپیکسل

مشخصات فنی

توضیحات

آیفون ۱۷ پرو مکس بزرگ‌ترین نمایشگر خانوادهٔ ۱۷ را با تراشهٔ A۱۹ Pro، بدنهٔ

شکل ۵-۱۷: صفحه‌ی جزئیات محصول با کارت خرید ثابت

ارسال رایگان برای سفارش‌های بالای ۱ میلیون و ۴۰۰ هزار تومان

سبد خرید

حساب من

جستجوی محصول، برند یا دسته‌بندی ...

تک‌شاپ
TECHSHOP

دسته‌بندی‌ها

صفحه اصلی

فروشگاه

وبلاگ

تماس با ما

درباره ما

تخفیف‌های ویژه

سبد خرید

۱ کالا

۱

سبد خرید

۲

اطلاعات و پرداخت

۳

تکمیل خرید

خلاصه سفارش

✓ ارسال سفارش شما رایگان است.

ارسال رایگان برای سفارش‌های بالای ۱,۴۰۰,۰۰۰ تومان

تعداد کالا

۱

پسته‌بندی و ارسال

رایگان

قیمت قابل پرداخت

۲۱۴,۰۰۰,۰۰۰ تومان

ادامه و ثبت سفارش

ادامه خرید

افزودن کالا به سبد خرید به معنی رزرو آن نیست؛ با توجه به محدودیت موجودی، سبد خود را ثبت و خرید را نهایی کنید.

جمع

۲۱۴,۰۰۰,۰۰۰ تومان

اپل iPhone ۱۷ Pro Max ظرفیت ۵۱۲ گیگابایت

برند

Apple

رنگ آبی سرمه‌ای

قیمت واحد ۲۱۴,۰۰۰,۰۰۰ تومان

۱

+

-

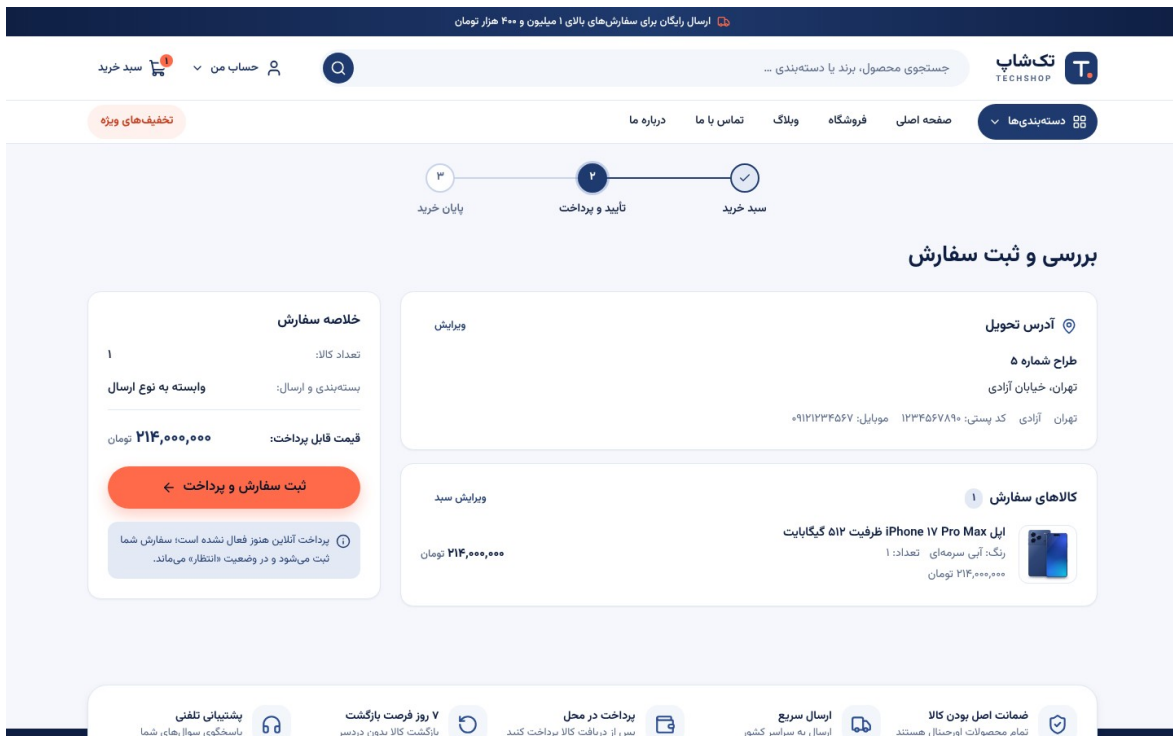
سبد خرید

۱ کالا

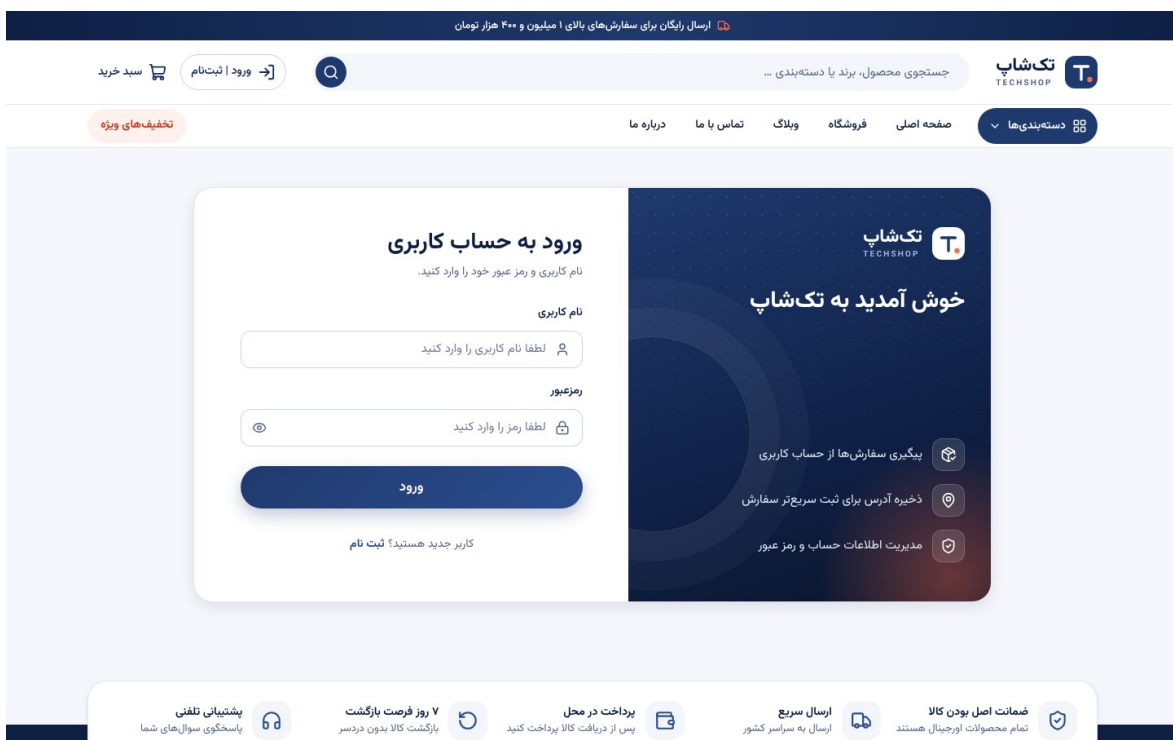
شکل ۵-۱۸: سبد خرید با نوار پیشرفت ارسال رایگان

۳۰

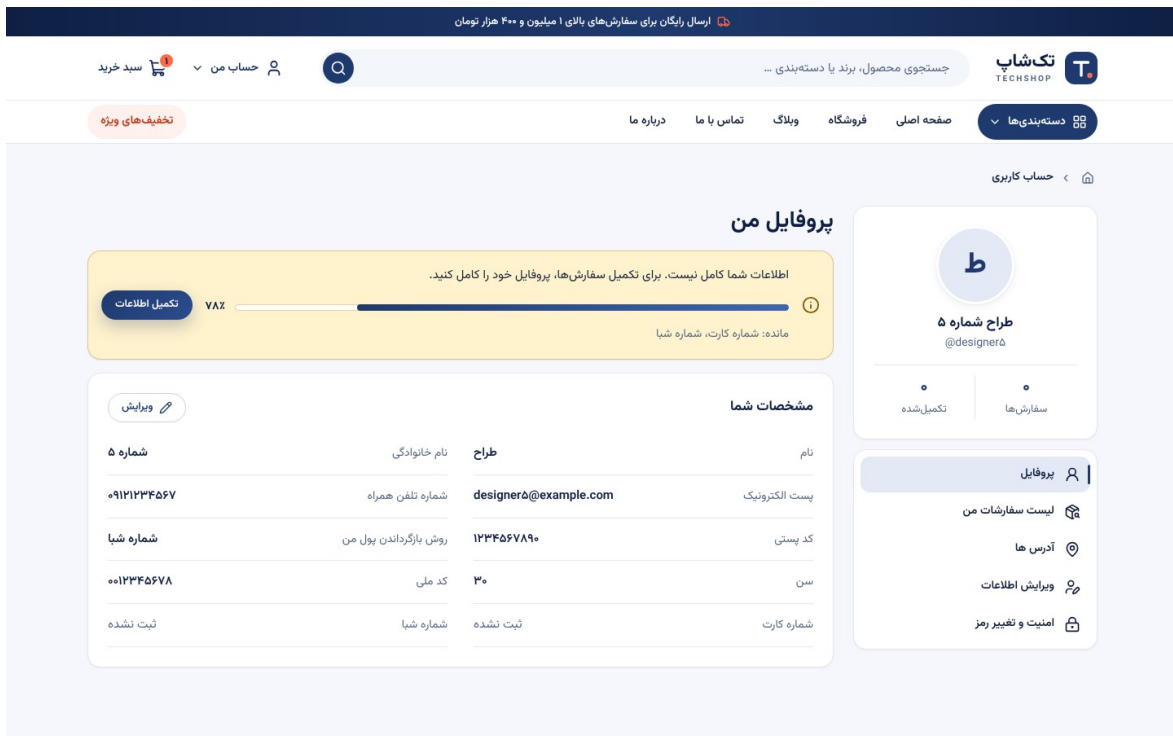
گزارش پروژه: طراحی و پیاده‌سازی فروشگاه اینترنتی تک‌شاپ



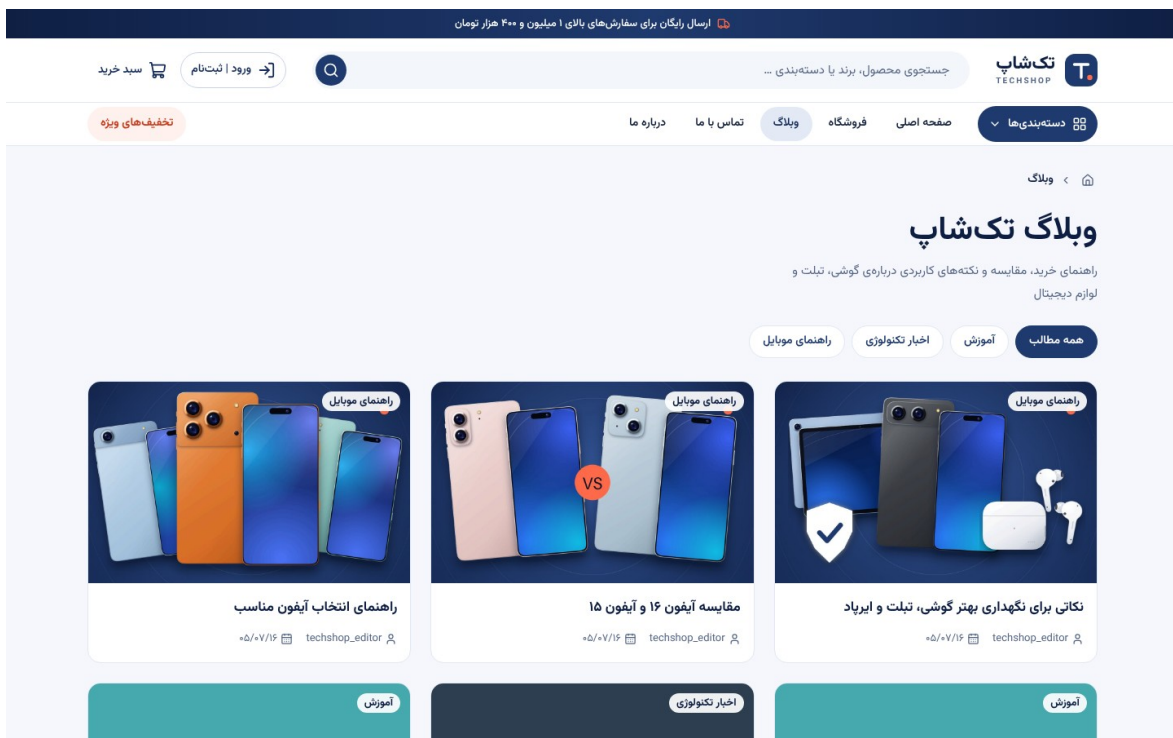
شکل ۵-۱۹: صفحه‌ی بررسی و ثبت سفارش



شکل ۵-۲۰: صفحه‌ی ورود با پنل برند



شکل ۵-۲۱: حساب کاربری و نوار کامل‌بودن پروفایل



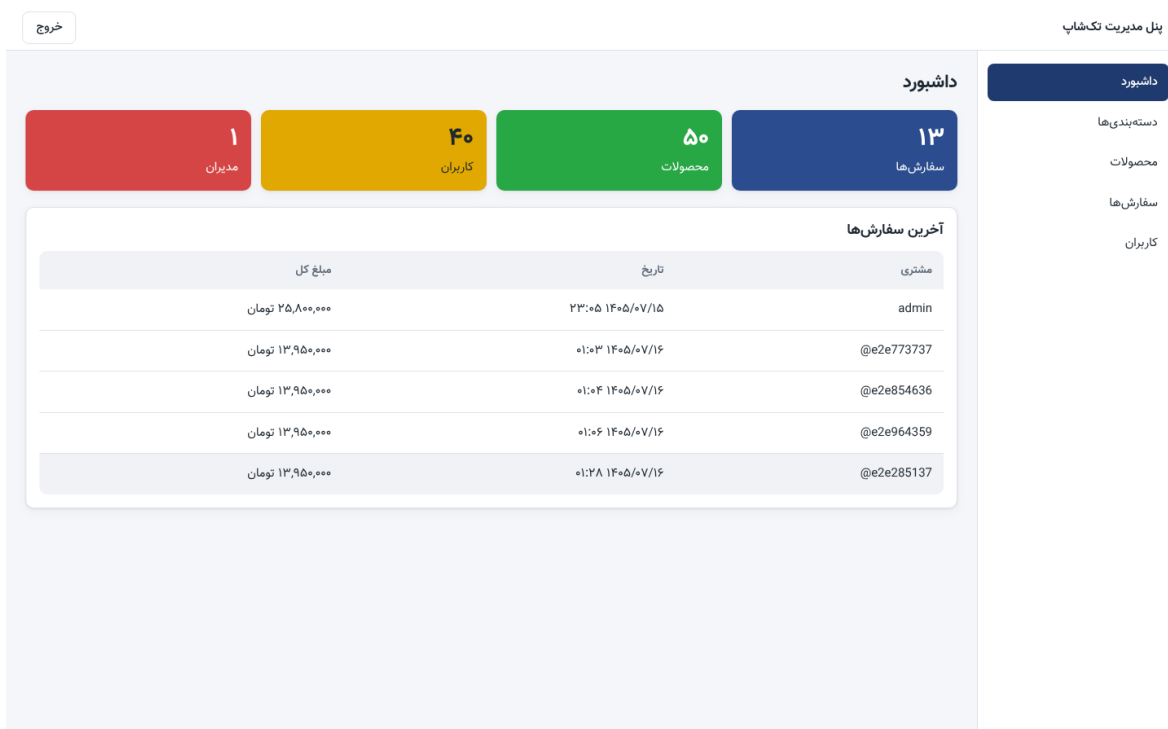
شکل ۵-۲۲: فهرست مقاله‌های وبلاگ با جلد تصویرسازی‌شده



شکل ۵-۲۳: صفحه اصلی در موبایل



شکل ۵-۲۴: منوی کشویی موبایل



شکل ۵-۲۵: داشبورد پنل مدیریت

۵-۵ داده‌ی نمونه و تصویرسازی

برای نمایش واقع‌نمای فروشگاه، دو دستور مدیریتی Django ساخته شد: seed_demo_catalog حدود ۴۳ محصول مربوط به سال ۲۰۲۳ به بعد (آیفون ۱۵ تا ۱۷، گلکسی S۲۴ و S۲۵، اولترا، آپید پرو/ایر/مینی و ایرپاد) می‌سازد و seed_demo_blog سه مقاله را ثبت می‌کند. دستورهای تکرارپذیرند (محصول موجود دوباره ساخته نمی‌شود) و گزینه‌ی --prune-old فقط مدل‌های نسخه‌ی قبلی سید را پاک می‌کند.

چون از محیط توسعه امکان دسترسی به عکس‌های رسمی نبود و استفاده از عکس‌های دارای حق نشر روا نیست، تصویر هر مدل به‌صورت برنامه‌نویسی با کتابخانه‌ی Pillow کشیده می‌شود (اسکرپت generate_demo_art.py). هر مدل چیدمان دوربین مخصوص خود را دارد. کاربر می‌تواند هر فایل را با عکس واقعی هم‌نام جایگزین کند.

فصل ۶: آزمون و ارزیابی

۶-۱ راهبرد آزمون

آزمون در سه سطح انجام شد: آزمون‌های خودکار سمت سرور (pytest) برای قواعد کسب‌وکار و امنیت، آزمون‌های انتهابه‌انتها (Playwright) برای سناریوهای فصل دوم، و بررسی‌های خودکار کیفیت رابط (سرریز، خطای کنسول، دسترس‌پذیری). افزون بر این، یک بازبینی امنیتی مستقل با چند بازبین انجام شد و ایرادهای یافت‌شده با آزمون پوشش داده شدند.

۶-۲ آزمون‌های سمت سرور

جدول ۶-۲۱: خلاصه‌ی آزمون‌های pytest (در مجموع ۱۷۳ آزمون موفق)

گروه	آنچه بررسی می‌شود	تعداد
accounts	ثبت‌نام، ورود/خروج، CSRF، محدودیت نرخ، پروفایل، گذرواژه، آدرس، سفارش‌های مشتری	۷۵
seed	دستورهای seed: تکرارپذیری، فقط ۲۰۲۳ به بعد، prune-old--، تصاویر معتبر	۲۰
shop، blog، contact	API عمومی، ثبت سفارش، قفل، قیمت و تخفیف، ورودی‌های ناهنجار، وبلاگ، فرم تماس	۷۸
جمع		۱۷۳

نمونه‌ای از آزمون‌های مهم: «درخواست ثبت سفارش دوم در حین اجرای اولی با ۴۰۹ رد می‌شود»؛ «قفل پس از موفقیت و پس از خطا آزاد می‌شود»؛ «تخفیف بیش از ۱۰۰ درصد به ۱۰۰ بریده می‌شود»؛ «جعل X-Forwarded-For محدودیت ورود را دور نمی‌زند»؛ «ارقام فارسی موبایل به ASCII ذخیره می‌شوند»؛ «تصویر بزرگ‌تر از ۲ مگابایت رد می‌شود»؛ «شکست CSRF در API پاسخ JSON و در صفحه‌ی ادمین پاسخ HTML می‌دهد».

۳-۶ آزمون‌های انتها به انتها

آزمون دودی با Playwright و مرورگر Chromium روی برنامه‌ی در حال اجرا انجام شد و در مجموع ۲۴ مرحله دارد؛ همه موفق بودند. آزمون پنل مدیریت نیز ۲۱ مرحله دارد (ورود با JWT، تازه‌سازی شفاف توکن، ساخت و حذف دسته‌بندی با تصویر، فهرست محصولات و جست‌وجوی کاربران).

جدول ۶-۲۲: مراحل آزمون انتها به انتهای فروشگاه

مرحله‌ها	گروه
دسته‌ی سریع صفحه‌ی خانه، ۱۲ محصول در هر صفحه و صفحه‌بندی، مرتب‌سازی ارزان‌ترین، فیلتر موجودی و برند، حالت خالی، جست‌وجوی هدر	مرور
تب‌ها، تعداد ۲ و شمارنده‌ی هدر، صفحه‌ی ۴۰۴، ماندگاری سبد، تغییر تعداد، حذف و سبد خالی	محصول و سبد
وبلاگ و فیلتر دسته، صفحه‌ی مقاله، فرم تماس با خطا و موفقیت	محتوا
ریدایرکت مسیرهای محافظت‌شده، ثبت‌نام با شرایط، ورود نادرست/درست، ثبت سفارش، وضعیت و فهرست سفارش، ویرایش پروفایل و آدرس، تغییر گذرواژه، خروج	حساب و خرید
نبود اسکرول افقی، منوی کشویی، کشوی فیلتر	موبایل
نبود خطای JavaScript و هشدار React	کیفیت

۴-۶ بازبینی امنیتی مستقل

بخش مشتری و ثبت سفارش در یک بازبینی خصمانه شرکت داده شد: چند بازبین مستقل با دیدگاه‌های متفاوت (احراز هویت و CSRF، دسترسی و نشت داده، درستی ثبت سفارش، پیامدهای حذف رابط قدیمی، درستی React) مشکلات را جست‌وجو کردند و هر یافته توسط دو منتقد دیگر رد یا تأیید شد. یافته‌های تأییدشده برطرف شدند. جدول زیر مهم‌ترین آن‌ها را نشان می‌دهد.

جدول ۶-۲۳: یافته‌های بازبینی امنیتی و رفع آن‌ها

یافته	شدت	اقدام
دور زدن محدودیت نرخ با جعل X-Forwarded-For	بالا	NUM_PROXIES از محیط؛ آزمون جعل هدر
ثبت سفارش تکراری با دوبار کلیک یا دو تب	بالا	قفل کاربر با cache.add و پاسخ ۴۰۹
خطای ۵۰۰ برای قیمت‌های ۱۰۰ میلیون به بالا	متوسط	افزایش max_digits و مهاجرت پایگاه داده

یافته	شدت	اقدام
تخفیف بیش از ۱۰۰ یا منفی، قیمت منفی می‌ساخت	متوسط	اعتبارسنج مدل و بریدن مقدار در سید و مرتب‌سازی
SECRET_KEY عمومی در مخزن	متوسط	بدون مقدار پیش‌فرض خارج از DEBUG و آزمون
ورود مدیر (JWT) بدون محدودیت نرخ	متوسط	افزودن LoginThrottle به نمای ورود
نام کاربری با نویسه‌های نامرئی و شبیه	پایین	الگوی @ + نویسه‌های انگلیسی
خواندن سید برای هر مهمان یک نشست می‌ساخت	پایین	Cart دیگر هنگام خواندن چیزی نمی‌نویسد
ورودی ناهنجار در API عمومی خطای ۵۰۰ می‌داد	پایین	اعتبارسنجی نوع و محدوده؛ پاسخ ۴۰۰
انقضای نشست در رابط دیده نمی‌شد	متوسط	رویداد سراسری و بازگشت به حالت مهمان
پاک‌شدن نام یا ایمیل بی‌صدا «ذخیره» گزارش می‌شد	متوسط	اعتبارسنج require_text و خطای فارسی
لینک «تکمیل آدرس» پروفایل را کامل نمی‌کرد	متوسط	شاخص address_complete در پاسخ پرداخت

۵-۶ کیفیت رابط کاربری

اسکرپیت بررسی صفحه همه‌ی مسیرها را در عرض‌های ۳۲۰، ۳۹۰، ۱۰۲۴ و ۱۴۴۰ پیکسل باز کرد و موارد زیر را سنجید: سرریز افقی، خطای کنسول و درخواست ناموفق، تصویر خراب، تصویر بدون alt، دکمه‌ی بدون نام، فیلد بدون برچسب، ساختار تیتل (یک h۱) و تباین متن. در نسخه‌ی نهایی برای همه‌ی ۲۱ مسیر بررسی‌شده هیچ مورد مسدودکننده‌ای باقی نماند.

جدول ۶-۲۴: اندازه‌ی بسته‌ی ساخته‌شده‌ی فرانت‌اند (بر حسب کیلوبایت)

فایل	حجم	حجم فشرده (gzip)
React و کتابخانه‌های مشترک	۱۶۳	۵۳
هسته‌ی ویتترین (مسیریاب، Provider، کیت)	۴۷	۱۴
صفحه‌ی فروشگاه	۲۱	۷
صفحه‌ی محصول	۱۸	۵
صفحه‌ی اصلی	۱۶	۴
پنل مدیریت	۱۸	۶
CSS ویتترین	۲۵	۵

به دلیل بارگذاری تنبل صفحه‌ها، مرورگر هنگام ورود به سایت فقط هسته، React و صفحه‌ی جاری را می‌گیرد (حدود ۸۰ کیلوبایت فشرده)، نه کل برنامه را.

۶-۶ جمع‌بندی ارزیابی

نتایج نشان می‌دهند اهداف جدول ۱-۱ برآورده شده‌اند: قابلیت‌های فرایند خرید با آزمون خودکار تأیید شده، مشکلات امنیتی مهم یافته و رفع شده‌اند و رابط در همه‌ی اندازه‌ها بدون سرریز کار می‌کند. محدودیت‌های شناخته‌شده در فصل بعد فهرست شده‌اند.

فصل ۷: نتیجه‌گیری و پیشنهادها

۷-۱ نتیجه‌گیری

در این پروژه یک فروشگاه اینترنتی کامل با معماری جداشده‌ی سرور و کاربر طراحی و پیاده‌سازی شد. سرور با Django و DRF قواعد کسب‌وکار، امنیت و داده را مدیریت می‌کند و رابط React با کیت طراحی اختصاصی تجربه‌ای روان، فارسی و واکنش‌گرا ارائه می‌دهد. سناریوی کامل خرید از مرور تا ثبت سفارش، همراه با حساب کاربری و پنل مدیریت، به‌طور خودکار آزموده شد.

درس‌های مهم کار عبارت بودند از: اهمیت جداسازی API از رابط، لزوم اعتبارسنجی در سرور (نه فقط رابط)، ارزش بازبینی امنیتی مستقل که ایرادهایی مانند دور زدن محدودیت نرخ با جعل یک هدر را آشکار کرد، و تأثیر کیت طراحی مشترک در یکدستی و سرعت ساخت صفحه‌ها.

۷-۲ محدودیت‌ها

جدول ۷-۲۵: محدودیت‌های نسخه‌ی فعلی

محدودیت	توضیح
درگاه پرداخت	متصل نیست؛ سفارش با تراکنش pending ذخیره می‌شود
موجودی انبار	هنگام ثبت سفارش از موجودی کم نمی‌شود
ایمیل و پیامک	ارسال اعلان وضعیت سفارش انجام نمی‌شود
تصویر محصولات	تصویرسازی نمایی است و عکس رسمی نیست
قلم ایران‌یکان	پروانه‌ی قلم تهیه نشده و Vazirmatn جایگزین است
ورود ادمین Django	پنل Jazzmin و api-auth/ محدودیت نرخ ندارند
استقرار تولید	سرو نسخه‌ی dist روی سرور باید به‌صورت دستی پیکربندی شود

۷-۳ پیشنهادها برای ادامه‌ی کار

- اتصال به درگاه پرداخت و پیاده‌سازی بازگشت از درگاه با تغییر وضعیت تراکنش.
- کاهش موجودی هنگام ثبت سفارش و رزرو موقت کالا در سبد.
- جست‌وجوی متنی پیشرفته با قابلیت Full-Text Search در PostgreSQL و پیشنهاد خودکار هنگام تایپ.

- ثبت دیدگاه و امتیاز کاربران برای محصول و نمایش میانگین.
- اعلان ایمیلی و پیامکی با Celery، و فهرست علاقه‌مندی‌ها.
- خط لوله‌ی CI/CD برای اجرای خودکار آزمون‌ها و ساخت تصویر Docker.
- افزودن آزمون‌های انتها به انتها به مخزن و اجرای آن‌ها در هر درخواست ادغام.

منابع

۱. Django Software Foundation, «Django documentation (version ۵.۰)», <https://docs.djangoproject.com/en/۵.۰/>
۲. /Encode, «Django REST framework», <https://www.django-rest-framework.org>
۳. /Meta Open Source, «React documentation», <https://react.dev>
۴. /Vite contributors, «Vite: Next generation frontend tooling», <https://vite.dev>
۵. PostgreSQL Global Development Group, «PostgreSQL ۱۶ Documentation», <https://www.postgresql.org/docs/۱۶/>
۶. /Redis Ltd., «Redis documentation», <https://redis.io/docs>
۷. /Celery Project, «Celery documentation», <https://docs.celeryq.dev>
۸. Cross-Site Request Forgery Prevention و «OWASP Foundation, «OWASP Top ۱۰:۲۰۲۱ Cheat Sheet», <https://owasp.org>
۹. W۳C, «Web Content Accessibility Guidelines (WCAG) ۲.۱», <https://www.w۳.org/TR/WCAG۲۱/>
۱۰. /Microsoft, «Playwright for end-to-end testing», <https://playwright.dev>
۱۱. Rastikerdar S., «Vazirmatn font», <https://github.com/rastikerdar/vazirmatn>
۱۲. /Lucide contributors, «Lucide icons», <https://lucide.dev>
۱۳. Fielding R. T., «Architectural Styles and the Design of Network-based Software Architectures», Doctoral dissertation, University of California, Irvine, ۲۰۰۰
۱۴. Sommerville I., «Software Engineering», ۱۰th ed., Pearson, ۲۰۱۶
۱۵. Fowler M., «Patterns of Enterprise Application Architecture», Addison-Wesley, ۲۰۰۲
۱۶. Object Management Group, «Unified Modeling Language (UML) Specification, version ۲.۵.۱», ۲۰۱۷

پیوست‌ها

پیوست الف: API مدیریتی (JWT)

جدول ۷-۲۶: گروه‌های API مدیریتی و مسیرهای هر گروه

منبع	مسیرها (پیشوند /shop/api/v1/ یا /accounts/api/v1/)	روش‌ها
دسته‌بندی	category-list, category-create, category-detail/{pk}, category-data/{pk}	GET, POST, PUT, DELETE
برند	brand-list, brand-create, brand-detail/{pk}, brand-data/{pk}	GET, POST, PUT, DELETE
محصول	product-list, product-create, product-detail/{pk}, product-data/{pk}	GET, POST, PUT, DELETE
سفارش	order-list, order-detail/{pk}, order-data/{pk}	GET, PUT, DELETE
قلم سفارش	orderitem-list, orderitem-detail/{pk}, orderitem-data/{pk}	GET, PUT, DELETE
فاکتور	invoice-list, invoice-detail/{pk}, invoice-data/{pk}	GET, PUT, DELETE
تراکنش	transaction-list, transaction-detail/{pk}, transaction-data/{pk}	GET, PUT, DELETE
کاربران	users-list, users-detail/{pk}, users-create, users-change-info/{pk}, users-delete/{pk}	GET, POST, PATCH, PUT, DELETE
پروفایل	users-profile, users-profile-detail/{pk}, users-change-profile/{pk}, users-profile-delete/{pk}	GET, PATCH, PUT, DELETE
فیلتر کاربران	user-order, user-complete, user-city, user-max-age, user-min-age, users/search/username	GET

منبع	مسیرها (پیشوند /shop/api/v1/ یا /accounts/api/v1/)	روش‌ها
احراز هویت	login (ورود مـ_____دیر)، / api/token/refresh/ //api/token/verify	POST
آمار پنل	admin-panel/api/v2/user-/ count, new-order, product-count	GET
وبلاگ و تماس	blog/api/v1/blog-list, category-/ /list, Visitor-list contact-us/api/v1/contact-list	GET, POST, PUT, DELETE

پیوست ب: دستورهای اجرا

اجرای پروژه بدون Docker

```
# بک اند
cd shop
python manage.py migrate
python manage.py seed_demo_catalog --prune-old
python manage.py seed_demo_blog --prune-old
python manage.py runserver 0.0.0.0:8001

# فرانت اند
cd frontend
npm install
npm run dev           # http://127.0.0.1:5173
npm run build         # خروجی در dist/

# آزمون‌ها
cd shop && pytest
```

پیوست پ: آمار پروژه

جدول ۷-۲۷: آمار کلی پروژه در زمان نگارش گزارش

شاخص	مقدار
تعداد کامیت‌ها	بیش از ۹۰
خط‌های Python (بدون مهاجرت)	حدود ۸,۶۰۰
خط‌های JavaScript و JSX	حدود ۷,۹۰۰
خط‌های CSS	حدود ۸,۱۰۰
مؤلفه‌ها و صفحه‌های React (ویترین / پنل)	۸۲ / ۱۸ فایل JSX
مسیرهای API	حدود ۸۰ (عمومی، مشتری و مدیریتی)
آزمون‌های pytest	۱۷۳
مراحل آزمون انتهابه‌انتها	۲۴ ویترین + ۲۱ پنل

شاخص	مقدار
محصولات داده‌ی نمونه	۴۳ محصول، ۳ مقاله، ۳ دسته‌ی کالا

پیوست ت: واژه‌نامه‌ی اصطلاحات

جدول ۷-۲۸: اصطلاحات فنی به‌کاررفته در گزارش

اصطلاح	برابر فارسی	توضیح کوتاه
API	رابط برنامه‌نویسی	مجموعه‌ی مسیرهایی که برنامه‌ها از راه آن با سرور داده ردوبدل می‌کنند
SPA	برنامه‌ی تک‌صفحه‌ای	برنامه‌ای که بدون بارگذاری مجدد صفحه، محتوا را در مرورگر عوض می‌کند
ORM	نگاشت شیء-گرا-رابطه‌ای	نگاشت جدول‌های پایگاه داده به کلاس‌های برنامه
CSRF	جعل درخواست بین‌سایتی	حمله‌ای که مرورگر کاربر واردشده را به ارسال درخواست ناخواسته وادار می‌کند
JWT	توکن وب JSON	توکن امضاشده برای احراز هویت بدون نشست سمت سرور
Session	نشست	داده‌ی موقت هر کاربر که سرور با یک کوکی به او نسبت می‌دهد
Throttling	محدودیت نرخ	محدود کردن تعداد درخواست در بازه‌ی زمانی
Serializer	سریال‌ساز	تبدیل مدل به JSON و اعتبارسنجی داده‌ی ورودی
Transaction	تراکنش	گروهی از عملیات پایگاه داده که یا کامل انجام می‌شود یا هیچ‌کدام
Atomic	اتمیک / تجزیه‌ناپذیر	ویژگی تراکنش که اجرای نیمه‌کاره را نمی‌پذیرد
Middleware	میان‌افزار	کدی که بین دریافت درخواست و اجرای نما قرار می‌گیرد
Lazy loading	بارگذاری تنبل	بارگذاری کد یا تصویر فقط زمانی که لازم می‌شود
Responsive	واکنش‌گرا	چیدمانی که خود را با اندازه‌ی صفحه‌ی نمایش تطبیق می‌دهد
Design token	توکن طراحی	متغیر نام‌دار برای رنگ، فاصله و سایر ویژگی‌های ظاهری

اصطلاح	برابر فارسی	توضیح کوتاه
EYE test	آزمون انتهابه‌انتها	آزمونی که رفتار کامل برنامه را از دید کاربر در مرورگر بررسی می‌کند
Seed	داده‌ی اولیه	داده‌ی نمونه‌ای که برای شروع به پایگاه داده افزوده می‌شود